K U S I N A K O D E

Kusina Kode System Primer

A lecture-style study module for the capstone defense. Every concept is taught the same way, and every example points to code that actually runs in Kusina Kode: the Android app, the PHP API on Azure, and the admin console.

1
Definition
The textbook concept.

2
Why it matters here
What problem it solves in Kusina Kode.

3
How we applied it
The real file, class or table.

4
In plain words
How to say it to a non-programmer.

5
Insights
Why we chose it, and supporting evidence.

BEFORE YOU START

Study plan

Eight sessions of about 45 minutes, starting with Unit 0, the manuscript summary. Read a unit, then answer its "Panel might ask" lines out loud without looking. Units 1 to 3 are the program itself; units 4 and 5 are how it is protected and hosted, and unit 6 ties it all together in the diagrams.

SESSION	UNIT	GOAL	YOU CAN EXPLAIN…
0	Manuscript summary	Know the whole paper	Each chapter in one minute, and the key numbers
1	OOP & architecture	Know how the code is organised	Why the app is split into screens, ViewModels, rules and repositories
2	Data structures	Know where data lives and why	Why a map, a set or a chain was the right container
3	Algorithms	Know the core logic step by step	How a guess becomes coloured tiles, and how XP and ranks are computed
4	Cybersecurity	Know what protects players and rewards	Passwords, tokens, lockout, encryption, and why the ledger can't be faked
5	Cloud computing	Know where it runs and how well	Each Azure service, what it costs us, and what the stress test showed
6	System diagrams	Walk through each figure in a minute	What every shape means in each diagram type, and how to walk through ours
7	Concept checks	Pass the panel's concept questions	Every card in Unit 7 out loud, the skill drills on paper, and the 45 panel questions

UNIT 0 · START HERE

Manuscript summary by chapter

The whole paper in bullets, chapter by chapter, from manuscript v2.30 (October 20, 2026). Study it together first: one member reads a chapter card aloud, the others answer its "Panel might ask" line, then switch.

Chapter 1 · Introduction background · objectives · scope

BACKGROUND

- Filipino cuisine carries regional identity, but learning content is **scattered** across videos, blogs, and social media.
- Pre-development survey (n = 64): YouTube 68.8%, family 64.1%, TikTok 59.4%; **mobile apps least used, 7.8%**.
- Chef Karen Nina B. Gicana: popular apps (Tasty, Pinterest) are international; **Mindanao cuisine** (Maranao, Tausug) is underrepresented.
- Gamified apps keep points and badges as **editable records** with no proof they are genuine (Motepalli & Jacobsen, 2021).

RESEARCH QUESTION

- How can a blockchain-based, gamified Filipino culinary word-puzzle app support culinary vocabulary and heritage learning, keep users engaged, and secure their rewards through a tamper-evident blockchain mechanism?

OBJECTIVES

- **A** · a module for culinary vocabulary, recipe-based learning, and cultural awareness through word puzzles
- **B** · a platform that encourages motivation, engagement, and continued participation through gamification
- **C** · blockchain technology to manage rewards, achievements, and activity records securely and verifiably (main contribution)

SCOPE

- Android app (Android 8.0+, Kotlin and Jetpack Compose) for players; web admin console (ASP.NET Web Forms) for administrators.
- Features: word puzzle with color-coded hints · heritage and recipe card after each round · points, badges, leaderboard, progress tracking · blockchain incentive system (private Proof-of-Authority ledger, KK Coins, TxHash receipts) · role-based user management.

DELIMITATIONS

- Filipino cuisine only; recipes are reference, not hands-on cooking instruction.
- **Does not measure** how effective the platform is at promoting learning.
- Does not cover regulation, taxation, or legal compliance of digital assets.
- Ledger is **tamper-evident, not decentralized**: one validator key held by the research team; KK Coins are not traded publicly.

CONCEPTUAL FRAMEWORK

- Input-Process-Output. **Input**: review of literature, Filipino culinary knowledge base, chef interview, survey.

- **Process**: Agile Scrum development, with blockchain incentive integration, admin console deployment, and usability testing.
- **Output**: the Kusina Kode mobile app, the admin console, and the blockchain-based reward and verification system.

Panel might ask: "Did you measure whether students learned more?" No; it is a delimitation. The study measures acceptance, quality, and usability; learning gains are the final recommendation.

Chapter 2 · Review of Related Literature `five themes · synthesis`

1 CULINARY HERITAGE

- Recipes carry cultural heritage; regional dishes are fading (Gelera et al., 2023); policy concern: Senate Bill No. 244, the Philippine Culinary Heritage Act.
- Technology can preserve and teach heritage (Partarakis et al., 2021); local studies describe no structured digital tool for Filipino culinary heritage.

2 GAMIFIED LEARNING

- Gamification raises motivation, engagement, and performance (Oliveira et al., 2023; Jaramillo-Mediavilla et al., 2024; Lampropoulos & Sidiropoulos, 2024).
- Balance intrinsic and extrinsic motivation; rewards must feel meaningful (John et al., 2023; Baah et al., 2023).
- Existing culinary apps target Western or general audiences and skip heritage.

3 BLOCKCHAIN INCENTIVES

- Hashing, signatures, and hash-linked blocks make records tamper-evident; Proof-of-Authority uses approved validators.
- Public platforms compared (Polygon, Ethereum, Solana, Hyperledger Fabric); a private PoA ledger avoids wallets and fees for players.
- Blockchain rewards in education increase trust and participation (Khanna, 2025).

4 ARCHITECTURE AND SECURITY

- Cloud models (IaaS, PaaS) on Microsoft Azure; MVVM and Clean Architecture for the app.
- AES-256, SHA-256, ECDSA; zero-trust API protection (Chandramouli & Butcher, 2025); NIST frameworks.

5 EVALUATION AND TESTING

- ISO/IEC 25010 software quality model; System Usability Scale (Brooke, 1996; 68 = average, Bangor et al., 2008); user acceptance testing.
- 5.4 Software Testing Approaches: testing levels (ISO/IEC/IEEE 29119-1); response-time limits 0.1 s / 1 s / 10 s (Miller, 1968; Nielsen, 1993); load testing (Jiang & Hassan, 2015); 16 ms frames (Google, n.d.); NIST SP 800-115 and OWASP Top 10; Android fragmentation (Wei et al., 2016).

SYNTHESIS

- No existing platform combines blockchain incentives, gamified learning, and Filipino culinary heritage (Table 1). That gap is the study's contribution.

Panel might ask: "Why not use Polygon or Ethereum?" Players would need wallets, seed phrases, and fees, and KK Coins are not meant to be traded; a private PoA ledger gives tamper-evidence without those costs.

Chapter 3 · Methodology

design · Scrum · architecture · testing · analysis

RESEARCH DESIGN

- Quantitative, descriptive-evaluative, developmental: build the system, then evaluate it against quality and usability benchmarks.

SCRUM

- Roles: Product Owner Chef Gicana · Scrum Master Jhan Maurice De Roxas · Development Team (Yowanna also QA tester).
- Events: sprint planning, sprint review, sprint retrospective; 12 sprints.

CLOUD AND SECURITY

- Azure, Southeast Asia: API and ledger on a VM (Standard_B2s, Ubuntu 22.04, IaaS); console on App Service B1 (PaaS); Azure SQL Database and Blob Storage; Key Vault; Microsoft Entra ID for admins.
- CIA triad in three layers: cryptographic data protection (TLS, AES-256-GCM) · blockchain tamper-evidence (SHA-256, ECDSA) · API access control (bearer tokens, zero trust).
- Three-tier architecture: Client tier · Middleware and Cloud Services tier · Blockchain Ledger tier.

SYSTEM TESTING

- Unit · integration · UI (Espresso) · security (Semgrep, OWASP ZAP, brute force, SQL injection) · stress · cloud deployment · browser and mobile compatibility.

RESPONDENTS

- Locale: Mapúa Malayan Colleges Laguna. Expert validator (1, purposive) · Cohort A: 20 Culinary Arts (13) and Hospitality Management (7) students, purposive · Cohort B: 40 students from other programs, convenience.
- Data gathering in three stages: pre-development survey · expert consultation (semi-structured) · system evaluation (23 test cases for the expert; ISO/IEC 25010 and SUS for all).

DATA ANALYSIS

- Weighted mean on a 4-point scale: 3.26–4.00 Strongly Agree · 2.51–3.25 Agree · 1.76–2.50 Disagree · 1.00–1.75 Strongly Disagree.
- SUS: odd items −1, even items 5 − answer, sum × 2.5 → 0 to 100; 68 = acceptable.
- Mann-Whitney U (cohorts, ordinal data, small groups) and Spearman's ρ (ISO vs SUS).

Panel might ask: "Why a four-point scale?" It forces a stance; a neutral middle can become a safe default (Kusmaryono et al., 2022).

Chapter 4 · Results and Discussion

12 sprints · testing · evaluation

GROUNDWORK 1–3

- S1 audit (Aug 10–17): no reward system, fixed grid of 20 dishes, repeated-letter defect.
- S2 survey and expert consultation (May 25–31).
- S3: 30 dish information sheets incl. 6 Mindanao dishes, validated by Chef Gicana on Sept 11 with no corrections.

PLAYER EXPERIENCE 4–6

- S4 Game Map and redesigned screens; console in 10 tabs, 4 groups.
- S5 engine: names up to 10 letters, 6 attempts, two-pass scoring; 29/29 unit tests.
- S6 points, badges, leaderboard, progress; 38/38 unit tests.

BLOCKCHAIN REWARDS 7

- Four phases: encrypt (AES-256-GCM) and hash (SHA-256) → sign (ECDSA) and PoA check → append to the chain → KKCoin/KKBadge rules and TxHash receipt.
- Custodial wallets; chain re-verified hourly; harness now 391/391 checks.

COMPLETING THE SYSTEM 8–10

- S8 heritage card and KODEX (six cultural fields).
- S9 Azure deployment; database 21 → 36 tables, 43 enforced links; 26/26 API integration tests.
- S10 admin console catalogs, players, KK Coins, Audit log; per-section access; 12/12 console integration tests.

TESTING 11

- Unit 198 (app) · 1,109 (console) · 391 (API), all passed.
- UI 45/45 opens (avg 0.35 s) · security: lockouts, injection refused, ZAP 0 High · stress: 2,316/2,316 requests, 0.25 → 1.6 s, database at 91% · cloud 42/43 (1 open finding: reward keys on the VM disk) · compatibility 55/55 browser and 30/30 device checks.
- QA Round 2 (Oct 19, v1.31): 13 checks, 11 passed, 2 scan reports.

EVALUATION 12

- 61 respondents (Oct 6, 9, 10): expert 23/23 test cases, ISO 4.00, SUS 87.5, cultural content 4.00.
- ISO/IEC 25010 overall 3.70 (FS 3.76 · PE 3.68 · U 3.69 · R 3.60 · S 3.70), all Strongly Agree.
- SUS: Cohort A 69.1 · Cohort B 70.9 · all 70.6 (Acceptable, near 68).
- Mann-Whitney: ISO $p = .220$, SUS $p = .706$ (no significant difference). Spearman $\rho = .59$, $p < .001$.
- Feedback: hints in early levels (6), more dishes (6), learning curve (5), lag (3), app store (3).

Panel might ask: "Why is SUS close to 68?" First-session difficulty (hints, learning curve) and lag on mid-range phones; the lowest items were R4, U6, and PE1.

Chapter 5 · Conclusion and Recommendations

per objective · next steps

CONCLUSIONS

- **A achieved**: 30 validated dishes, accurate puzzle (FS1 3.79), cultural content 4.00.
- **B achieved**: accurate points and badges (FS5 3.84, 38/38 tests); motivation to keep playing lower (U4 3.57).
- **C achieved**: TxHash receipts, hourly verification, 391/391 checks; coins match what was earned (FS8 3.85, highest item); limit: single validator key.
- Intrinsic motivation from puzzle and heritage; extrinsic from points, badges, KK; the ledger makes the extrinsic rewards trustworthy.

RECOMMENDATIONS

- Better onboarding (region first, free early hint, skippable animations).
- More dishes, especially Mindanao, validated by an expert panel; review ingredient lists.
- Independent validators or public anchoring of block hashes.
- Before release: faster animated screens, higher database tier, remaining tests on staging, Key Vault for reward keys, Google Play.
- Test high-contrast tiles with color-blind players; one supervised evaluation procedure; longitudinal study of learning gains.

Panel might ask: "So does Kusina Kode improve learning?" Not shown; we measured acceptance. That is exactly our last recommendation.

Numbers to know by heart `all from v2.30`

WHAT	NUMBER
Survey respondents (pre-development)	64
Validated dishes	30 (6 from Mindanao)
Evaluation respondents	61 = 1 expert + 20 Cohort A + 40 Cohort B
Before screening	81 (SUS 65.6)
Expert test cases	23 / 23 passed
ISO/IEC 25010 overall	3.70 (Strongly Agree)
Highest / lowest item	FS8 3.85 / R4 3.43
SUS	Expert 87.5 · A 69.1 · B 70.9 · all 70.6
Mann-Whitney p	ISO .220 · SUS .706
Spearman ρ	.59 (students .58)
Unit tests	198 app · 1,109 console · 391 API
Integration tests	26 API · 12 console · 4 cross-system
API stress	2,316 requests, 0 errors, 0.25 → 1.6 s, DB 91%
Cloud test	42 / 43 passed, 1 open finding
Chain at cloud test	4,315 blocks verified in 6.5 s
Compatibility	55 / 55 browser · 30 / 30 device checks
QA Round 2	13 checks: 11 passed, 2 scan reports
Database	36 tables, 43 enforced links

Where things are in the appendices A to AD

APPENDIX	CONTAINS
A–D	ERD, DFD, use case, activity diagrams, process flows, pipelines
E–G	request letters, summary of the expert interview
H–I	documentation pictures, survey responses
J–L	dish validation request, certification, sources of dish content
M–N	unit tests: puzzle engine, gamification
O–P	integration tests: API, admin console
Q–T	UI test, security, stress, cloud deployment
U	results before screening (81) and the SUS data check
V–W	browser and mobile compatibility
X	user interface screens
Y–Z	consent and the questionnaire
AA	expert test case results
AB–AC	data dictionary, project timeline
AD	QA Round 2 test log

UNIT 1

Object-oriented programming & architecture

The app is written in Kotlin and the admin console in C#; both are object-oriented. In the app alone there are 114 data classes, 15 interfaces, 16 enums, 59 singleton objects and 8 ViewModels.

1.1 Classes and objects `data class · enum · object`

DEFINITION

A **class** is a blueprint that bundles data (properties) with the behaviour that works on it (methods). An **object** is one instance made from that blueprint.

WHY IT MATTERS HERE

Kusina Kode handles many "things" with their own data: levels, players, badges, ingredients, attempts. Modelling each as a class keeps its data and rules together and consistent everywhere they are used.

HOW WE APPLIED IT

- **Data classes** for records, e.g. `PlayerProgress` (points, streaks, solved levels) and `LevelData`. Kotlin generates equality and copying for them, so `current.copy(totalPoints = …)` makes a new updated record safely.
- **Enums** for fixed choices: `Region` (Luzon, Visayas, Mindanao), `Rarity`, `TileState` (Correct, SemiCorrect, Wrong), `PowerUp`.
- **Singleton objects** for one shared rulebook: `WordleEngine`, `ScoreRules`, `ChefRank`, `IngredientCatalog`.

IN PLAIN WORDS

A class is the recipe card; an object is the dish you cook from it. Every level in the game is cooked from the same "level" recipe, so they all have a word, a region and ingredients.

INSIGHTS

Data classes are **immutable by habit** in the app: progress is replaced with `copy()` rather than edited in place, which avoids half-updated scores when several screens read the same data.

Enums stop impossible values: a tile can only be one of three states, so a typo like "corect" can't compile.

Panel might ask: "Why use a singleton for the scoring rules?" Because there must be exactly one rulebook; two copies could score the same round differently.

1.2 Encapsulation `private · read-only views`

DEFINITION

Hiding an object's internal state and exposing only controlled ways to read or change it.

WHY IT MATTERS HERE

Game state (the board, the timer, the KK balance) must only change through the game's rules; a screen should never be able to set "you won" directly.

HOW WE APPLIED IT

```
// GameViewModel.kt
private val _uiState = MutableStateFlow(…)   // only the ViewModel can change it
val uiState = _uiState.asStateFlow()         // screens get a read-only view
```

- The same pattern guards `PantryViewModel`, `KkBalance` and the gamification store (`private set` on `gamification` in `KusinaKodeApp`).
- On the web, ASP.NET pages reach data only through the composition root and service classes (`DishService`, `IngredientService`), never straight to SQL.

IN PLAIN WORDS

The kitchen has one door for orders. Diners can see the food, but only the cook can change it.

INSIGHTS

This is also a security property: if the screen can't change the score, a bug in a screen can't award free KK. The server re-checks everything anyway (see 4.2).

1.3 Abstraction `interfaces`

DEFINITION

Describing *what* something does through an interface while hiding *how* it does it.

WHY IT MATTERS HERE

The game needs data from several places: the phone's storage, the PHP API, the chain. The game logic shouldn't care which one answered.

HOW WE APPLIED IT

- 15 repository interfaces, e.g. `GamificationRepository`, `PantryRepository`, `LevelRepository`, `AuthRepository`, `WalletRepository`.
- The coordinator only knows the interface: `GamificationCoordinator(repository: GamificationRepository, …)`.
- The web console does the same with `IIngredientStore`, `IReelStore` and `IAdminSignIn` in `Web_KusinaKode/Abstractions`.

IN PLAIN WORDS

> The game asks "give me the pantry". It doesn't need to know whether the answer came from the phone or from the server.

INSIGHTS

Abstraction is what made the unit tests possible: tests swap in fake repositories, so `ProgressRules` and `BadgeRules` are tested without a phone or internet.

It also let the team move from local XAMPP to Azure without rewriting the game logic.

1.4 Inheritance `extends Android & ASP.NET base classes`

DEFINITION

A class reusing and extending another class's behaviour (a subclass "is a" kind of its parent).

WHY IT MATTERS HERE

Android and ASP.NET already provide lifecycle, memory and request handling. Inheriting from their base classes gives Kusina Kode those features for free.

HOW WE APPLIED IT

- `class KusinaKodeApp : Application()` : runs once when the app starts (sets up the network status, gamification store, chain coordinator).
- `class GameViewModel(…) : ViewModel()` and seven other ViewModels: survive screen rotation and are cleared automatically.
- Each admin page (`Levels.aspx.cs` , `Audit.aspx.cs` …) inherits from ASP.NET's `Page` ; the shared `Admin.master` layout gives every page the sidebar and sign-in check.

IN PLAIN WORDS

Instead of building our own kitchen, we rented one and added our own recipes.

INSIGHTS

The code favours **composition over deep inheritance**: our own classes rarely extend each other. They combine small parts (a repository, a coordinator) instead, which keeps them easier to test and change.

1.5 Polymorphism `one interface, many forms`

DEFINITION

One interface or type can stand for many concrete forms, and the right behaviour is chosen at run time.

WHY IT MATTERS HERE

Some features have several sources or outcomes: the same "progress" can be stored locally or remotely, and a guess can be valid or invalid in several ways.

HOW WE APPLIED IT

- **Interface polymorphism:** `LocalGamificationRepository`, `RemotePantryRepository`, `RemoteAttemptRepository` are concrete forms of their repository interfaces.
- **Sealed types:** `WordleEngine.GuessValidation` is `Valid`, `Incomplete`, `WrongLength(expected, actual)` or `NotLetters`. The compiler forces every screen to handle all four.
- `NotificationGlyph` is either `Art` (a bundled picture) or `Remote` (a web picture), drawn differently.

IN PLAIN WORDS

"Serve the dish" works for adobo or sinigang; each one knows how it should be plated.

INSIGHTS

Sealed types turn "did we handle every case?" into a compile error instead of a crash. When a new validation case is added, every place that forgot it stops compiling.

1.6 MVVM, Repository & Clean Architecture `design patterns`

DEFINITION

MVVM separates the View (screen), ViewModel (state and actions) and Model (data and rules). The **Repository** pattern hides data sources behind one class. **Clean Architecture** arranges code in layers where inner rules never depend on outer details. The **Observer** pattern lets screens react automatically when data changes.

WHY IT MATTERS HERE

The project rule (`CLAUDE.md`) is that screens never call the network or database directly. Four people work on different modules, so clear layers prevent stepping on each other.

HOW WE APPLIED IT

- **App:** Compose screens → ViewModels exposing `StateFlow` (observer) → repositories → `KusinaApi` (Ktor HTTP client). Pure rules live in `domain/` with no Android code.
- **Web console:** Kyla split it into `KusinaKode.Domain` (rules, with tests), `Application` (services), `Data` (stores) and `Presentation` (pages), wired in one composition root.

IN PLAIN WORDS

> The waiter (screen) takes the order, the head cook (ViewModel) decides what happens, and the pantry staff (repository) fetch ingredients. Nobody does someone else's job.

INSIGHTS

Because the rules are separate, the same tile-scoring and XP logic is unit-tested on its own (`WordleEngineTest` , `ScoreRulesTest` , `ProgressRulesTest`). Defect D-01 (wrong colours for repeated letters) was found and fixed in that layer.

Panel might ask: "Why not let screens call the API?" A slow network would freeze the screen, and every screen would duplicate error handling. The ViewModel layer does both in one place.

UNIT 2

Data structures

Choosing the right container decides how fast the app can find, check and store things. Each structure below is used on purpose.

2.1 Lists and arrays `the guess grid`

DEFINITION

An ordered collection where each element has a position (index 0, 1, 2…).

WHY IT MATTERS HERE

A guess is a row of letters, and each letter's colour depends on its **position**. Order is the whole point.

HOW WE APPLIED IT

`WordleEngine.evaluate()` returns `List<TileState>`, one state per letter, built with `MutableList(ans.length) { TileState.Wrong }`. The board is a list of these rows: six rows for every dish (`MAX_ATTEMPTS = 6`).

IN PLAIN WORDS

A row of numbered boxes. Box 1 checks letter 1, box 2 checks letter 2, and so on.

INSIGHTS

The list is sized from the answer's length, not fixed. That is how the project meets its **variable word length** requirement: ADOBO makes 5 boxes, SINIGANG makes 8, with no special cases.

2.2 Hash maps `key → value in one step`

DEFINITION

A map stores key-value pairs and finds a value from its key in roughly constant time, O(1), no matter how many entries it holds.

WHY IT MATTERS HERE

The app constantly looks things up by name or id: a letter's remaining count, an ingredient's picture, an ingredient's details.

HOW WE APPLIED IT

- `remaining = mutableMapOf<Char, Int>()` in the tile algorithm counts unused answer letters.
- `IngredientArt.byName` maps about 200 dataset ingredient names to their photos.
- `IngredientCatalog.byId` maps ids like `ing_tuna_fresh` to ingredient records.

IN PLAIN WORDS

A labelled spice rack: you go straight to "garlic" instead of opening every jar.

INSIGHTS

Scanning a list of 123 ingredients for every tile on a dish page would repeat that work for each tile; a map answers each lookup at once. Maps also made the 1.23 fix simple: when a web name isn't in the picture map, the app looks it up by id instead.

2.3 Sets `membership without duplicates`

DEFINITION

A collection of unique items, built for fast "is X in here?" checks.

WHY IT MATTERS HERE

"Has this player already solved this dish?" decides whether a win pays XP and KK. It must be fast and must never count a dish twice.

HOW WE APPLIED IT

`PlayerProgress.solvedLevels` is a `Set<Int>`. In `ProgressRules.advance()`: `if (event.levelId in current.solvedLevels) return current`, so a replay changes nothing. `regionsSolved` and `newIngredientIds` are sets too.

IN PLAIN WORDS

A stamp card: each dish gets one stamp, and stamping it again doesn't add a second.

INSIGHTS

This set is the anti-farming rule. Defect D-05 ("replaying a solved dish awarded points") was fixed by checking this set first. The stress test confirmed it: replays showed "Already solved, +0".

2.4 Streams and queues `StateFlow · event bus · chain queue`

DEFINITION

A **queue** processes items in arrival order (first in, first out). A **stream** (flow) delivers a sequence of values over time to whoever is listening.

WHY IT MATTERS HERE

Many things happen after a win: XP, badges, KK, the chain receipt, the palayok. They must happen in order, even if the player is already on another screen.

HOW WE APPLIED IT

- Screens observe `StateFlow` streams; when the value changes, the screen redraws.
- `GameEvents` / `GamificationEvents` broadcast "round completed", and `GamificationCoordinator` listens for the whole app lifetime.
- `ChainQueue` lines up reward transactions for the ledger; on the server, a job settles anything still pending every 15 minutes.

IN PLAIN WORDS

Orders go on a rail in the kitchen and are cooked one after another, so none are lost when it gets busy.

INSIGHTS

Defect D-31 ("two rewards at once both fail") is exactly the problem queues solve: two writes racing for the same ledger. Ordering them, plus the server-side settle job, removes the race.

2.5 Hash-linked chain `blocks.jsonl`

DEFINITION

A linked list where each element (block) stores the **hash of the previous block**, so the whole list is chained together. This is the core data structure of a blockchain.

WHY IT MATTERS HERE

The study's third objective is a tamper-resistant reward record. Every KK earned or spent must be provable later.

HOW WE APPLIED IT

The server keeps the chain in `/var/lib/kusinakode/chain/blocks.jsonl`, one block per line, with each transaction in `txs/`. `lib/chain.php` computes each block's hash and checks the chain's tip; the database stores only receipts (`tx_ref` in `reward_claims`, `shop_unlocks`, `ingredient_draws`).

IN PLAIN WORDS

A receipt book where each page carries a fingerprint of the page before it. Tear out or change one page and every page after it stops matching.

INSIGHTS

Why a file and not a SQL table? Because the database is meant to be the editable working copy, while the chain is the evidence. An admin can edit a table, but cannot silently edit a block without breaking every later hash. The hourly integrity check on the Audit page detects exactly that.

2.6 Relational tables `20 tables · keys · relationships`

DEFINITION

Data stored in tables of rows and columns, linked by **primary keys** (unique id per row) and **foreign keys** (a column pointing at another table's key).

WHY IT MATTERS HERE

Players, levels, attempts, rewards and ingredients all relate to each other, and the admin console, analytics and leaderboard query across them.

HOW WE APPLIED IT

Azure SQL holds 20 tables (see the ERD). Examples: `attempts.user_id → users.id`, `attempts.level_id → levels.id`, enforced with `ON DELETE CASCADE`. Composite keys stop duplicates, e.g. `reward_claims`' key is `(user_id, kind, claim_key)`, so one first-dish bonus per player per dish.

IN PLAIN WORDS

Linked spreadsheets: the attempts sheet doesn't copy player names, it just points to the player's row.

INSIGHTS

The composite key on `reward_claims` makes double payouts impossible at the database level, not just in code. Cascading deletes explain a real event: deleting a level also deleted its attempts, which is why the console now refuses to remove played levels.

UNIT 3

Algorithms

The step-by-step procedures behind the game. Each one is small, deterministic and unit-tested.

3.1 Two-pass tile scoring `WordleEngine.evaluate · O(n)`

DEFINITION

A **multi-pass algorithm** walks the data more than once, each pass doing one job, so later passes can rely on what earlier passes decided.

WHY IT MATTERS HERE

This is the heart of the puzzle: turning a guess into green (correct), yellow (in the word, wrong place) and grey (not in the word), and it must handle repeated letters correctly.

HOW WE APPLIED IT

```
Pass 1: for each position i
          if guess[i] == answer[i] → Correct (green)
          else count answer[i] in remaining
Pass 2: for each position not yet green
          if remaining[guess[i]] > 0 → SemiCorrect (yellow),
remaining -1
          else → Wrong (grey)
```

Example: answer **SISIG**, guess **SINGS** → S I green, N grey, G yellow, the second S yellow (exactly what the booth screenshot shows).

IN PLAIN WORDS

First mark every letter that's in the exact right spot. Then, with the letters left over, mark the ones that exist somewhere else, and never more times than they appear in the answer.

INSIGHTS

The original Capstone 1 code used a one-pass `indexOf()`, which matched the first occurrence and showed too many yellows for repeated letters (defect D-01). Two passes plus a count map fix it.

Time is **O(n)** for an n-letter word: two passes, each with constant-time map lookups. That's instant even for long dish names.

Panel might ask: "Why two passes?" Because greens must be claimed first; otherwise a yellow could use up a letter that a later position needs for a green.

3.2 The XP formula `ScoreRules.pointsFor`

DEFINITION

A **deterministic scoring function**: the same inputs always give the same output, with no randomness.

WHY IT MATTERS HERE

XP must reward skill fairly and be reproducible: the same round always scores the same on any phone, which the acceptance criteria call "consistent across sessions".

HOW WE APPLIED IT

```
XP = 100                          // solved the dish
   + 20 × (6 - tries used)        // tries left over
   + 50 if solved on the 1st try
   + 60 (<30 s) / 40 (<60 s) / 20 (<120 s) / 0
```

Range: **100** (last try, slow) to **310** (first try, under 30 s). Losses and replays score 0.

IN PLAIN WORDS

You get 100 for solving it, plus bonuses for needing fewer tries, nailing it first time, and being quick.

INSIGHTS

Bonuses use **buckets** (under 30 s, under 60 s…) rather than exact seconds, which the code comments say makes a score "easy to explain to a player, and easy to re-derive if the chain ever needs to audit it".

3.3 Multi-key sorting `LeaderboardRules.rank`

DEFINITION

Sorting by a primary key and breaking ties with secondary keys, using a stable comparison sort (O(n log n)).

WHY IT MATTERS HERE

A leaderboard must give everyone a clear, fair position, even when two players have the same points.

HOW WE APPLIED IT

```
rows.sortedWith(
  compareByDescending { it.points }      // 1. most XP
    .thenByDescending { it.correctCount } // 2. more dishes
solved
    .thenBy { it.name.lowercase() })      // 3. A-Z, so ties
are stable
```

IN PLAIN WORDS

Rank by score; if tied, whoever solved more dishes goes higher; if still tied, alphabetical.

INSIGHTS

The final alphabetical key means the order never "flickers" between refreshes for tied players, which players would otherwise read as a bug.

3.4 Threshold lookup & gated progression

`ChefRank · UnlockManager`

DEFINITION

Mapping a number onto ordered ranges (thresholds), and a **state machine** that only allows the next step when the current one is finished.

WHY IT MATTERS HERE

Ranks and level unlocking are the progression that motivates players (objective 2).

HOW WE APPLIED IT

- `ChefRank`: Kusinero 0 → Line Cook 5 → Sous Chef 10 → Head Chef 20 dishes → Kusina Master when every visible dish is solved. The steps match the round badges, so a rank and its badge arrive together.
- `UnlockManager.unlockNextLevel()` unlocks only level N+1, and only if the level just won is the current highest N.

IN PLAIN WORDS

Like a cooking school: you move from apprentice to head chef as you master more dishes, and each class opens only after you pass the one before.

INSIGHTS

Ranks count **dishes solved, not XP**, so a rank reflects how much of the cuisine you've learned, not how fast you type. "Kusina Master" is tied to the total of visible dishes, so it adjusts automatically when admins add levels.

3.5 String normalisation & matching `IngredientArt.forName`

DEFINITION

Converting text to one canonical form (lowercase, letters and digits only) before comparing, often with regular expressions, plus a **fallback chain** when the first lookup fails.

WHY IT MATTERS HERE

Ingredient names arrive written in different ways: "White vinegar", "WHITE VINEGAR", "Vinegar (White/Cane/Coconut)" from the web console.

HOW WE APPLIED IT

```
key = name.lowercase().replace(Regex("[^a-z0-9]+"), "
").trim()
1. look up key in the picture map
2. else find the ingredient with that name in the catalogue → its id
3. else try "ing_" + key as an id
→ pantry picture for that id, or null (drawn icon)
```

IN PLAIN WORDS

Ignore capitals and punctuation, then try three ways to recognise the ingredient before giving up and drawing a simple icon.

INSIGHTS

Before 1.23, 55 of the web's 123 ingredient names showed a plain icon because only step 1 existed. The test `every ingredient in the book has a picture by its name` now guards all 123.

3.6 Hashing & digital signatures SHA-256 · ECDSA

DEFINITION

A **cryptographic hash** (SHA-256) turns any data into a fixed 64-character fingerprint; changing one character changes the whole fingerprint. A **digital signature** (ECDSA) proves who created a message and that it wasn't altered.

WHY IT MATTERS HERE

They are the algorithms that make the reward ledger trustworthy.

HOW WE APPLIED IT

- Each receipt's id is `'0x' . hash('sha256', kk_canonical_json($receipt))`: canonical JSON first, so the same receipt always hashes the same.
- Blocks are signed with `openssl_sign(…, OPENSSL_ALGO_SHA256)` using an elliptic-curve key on **secp256k1** (the curve Ethereum and Polygon use), with prime256v1 as a fallback on servers without it.
- Custodial wallet addresses are derived from the public key's SHA-256 hash.

IN PLAIN WORDS

The hash is a fingerprint of the receipt; the signature is the system's stamp. Change the receipt and the fingerprint won't match; fake the stamp and it won't verify.

INSIGHTS

Canonical JSON matters: the same data with keys in a different order would otherwise produce a different hash and look "tampered". The unit suite (`api/tests/run.php`) checks these primitives. It has grown to 391 checks across all four pipeline phases, all passing on October 13 and again in QA Round 2 on October 19, 2026.

UNIT 4

Cybersecurity

Security follows the CIA triad: **confidentiality** (only the right people see data), **integrity** (data isn't changed without detection) and **availability** (the system stays usable). Each module below protects one or more of the three.

4.1 Authentication `bcrypt · bearer tokens · Google · Entra`

DEFINITION

Proving a user is who they claim to be, and keeping that proof safe afterwards.

WHY IT MATTERS HERE

Accounts hold KK, badges and progress. A stolen account is stolen rewards.

HOW WE APPLIED IT

- Passwords are stored only as **bcrypt hashes** (`password_hash(…, PASSWORD_DEFAULT)`) and checked with `password_verify`; the plain password is never stored.
- After login the server issues a random token (`random_bytes`), stores only its **hash** in `api_tokens.token_hash`, and expires it after 30 days. Logging out deletes it.
- The phone sends it as `Authorization: Bearer …` (`KtorClient`).
- Players can sign in with Google (verified server-side); admins sign in to the console with Microsoft Entra.
- **Every sign-up and sign-in is also recorded on the ledger.** After a successful sign-in, the API sends a **0 KK** event, `account_signup` for a new account or `account_login` for a returning one, through the same four-phase reward pipeline (`login.php`, `register.php`, `auth/google.php`). It becomes a signed, hash-linked block with its own receipt, and the app's reward history lists it as "Account Login" or "Account Sign Up", marked **Secured** instead of a KK amount.

IN PLAIN WORDS

Your password is turned into an unreadable fingerprint before it's saved. After you log in, you get a temporary pass, and the server only keeps a fingerprint of that too.

INSIGHTS

Hashing tokens server-side means even a leaked database can't be used to log in as players. Before the 17 Aug security review, signing out left tokens valid for 30 days (D-25); now logout revokes them.

The blockchain does **not** decide who can sign in: the password check, the Google check, the token and the lockout all use the database. The ledger only **records** that a sign-in happened, so account activity has the same tamper-evident trail as rewards (the "activity records" of Objective C). The code says why: the same ledger entry is written whichever way a player signs in, so the audit log reads the same.

4.2 Authorization `identity from the token, never the request`

DEFINITION

Deciding what an authenticated user is allowed to do. The server must derive "who you are" from a trusted credential, not from what the client says.

WHY IT MATTERS HERE

Every reward is tied to a user id. If a client could send any `user_id`, it could write progress into someone else's account.

HOW WE APPLIED IT

- Endpoints call `kk_require_user()`, which reads the bearer token and ignores any `user_id` in the body (fix for D-14, then D-17 for the last four endpoints).
- Admin console: every page re-checks the signed-in admin and their allowed sections (`AdminAuth.IsActiveAdmin`), fails closed if unsure, and signs out after 15 minutes idle.
- Players never touch wallet keys: wallets are **custodial**, managed on the server.

IN PLAIN WORDS

The server doesn't believe "I'm player 46". It checks your pass and decides for itself who you are.

INSIGHTS

D-14 was rated **Critical**: "identity was a claim rather than a credential". It's a classic example of broken access control, the top risk on the OWASP Top 10.

4.3 Brute-force & enumeration defence

`lockout · rate limits · generic errors`

DEFINITION

Limiting repeated guesses and avoiding messages that reveal whether an account exists.

WHY IT MATTERS HERE

Login and password-reset codes can be guessed by a script if attempts are unlimited.

HOW WE APPLIED IT

- Every attempt is logged in `auth_attempts`; the 4th wrong password within 15 minutes, or the 6th wrong reset code, locks that account for 15 minutes (HTTP 429), as tested on a local copy on October 13 and 19 and repeated on the live API ("Too many attempts. Try again in … minutes").
- Lockout is per account, not per network (D-33): one person's mistakes on campus Wi-Fi don't lock everyone else.
- Reset codes are bcrypt-hashed and never returned in the API (D-20). Sign-up no longer says which emails exist (D-22), and database errors aren't shown to clients (D-23).

IN PLAIN WORDS

Get the password wrong too many times and that account takes a short break. And the app never confirms whether an email is registered.

INSIGHTS

Returning the reset code in the API response (D-20) meant anyone could reset anyone's password: a full account takeover. It was found by a security review, not by a user, which is why reviews are part of testing.

4.4 Data protection `TLS · AES-256 · secrets · privacy`

DEFINITION

Keeping data confidential **in transit** (encryption over the network) and **at rest** (encryption on disk), and keeping secrets out of code.

WHY IT MATTERS HERE

Tokens, emails and wallet keys pass through phones, Wi-Fi networks and a public GitHub repository.

HOW WE APPLIED IT

- **In transit:** HTTPS with Let's Encrypt certificates (certbot on the API VM); the app's `network_security_config` governs its connections.
- **At rest on the phone:** the token lives in `EncryptedSharedPreferences` (AES-256-GCM, key in the Android Keystore), and `allowBackup="false"` keeps it out of device backups (D-24).
- **At rest on the server:** reward payloads use AES-256-GCM; the master key and wallet private keys live in a vault (`lib/vault.php`), "never in source, in SQL".
- **Key Vault (as of October 19, 2026):** the console's secrets and connection string and the API's database password are read from Azure Key Vault. The reward encryption, validator, and reward keys remain on the VM disk, readable only by the server account, with an encrypted copy kept off the machine: the one open finding of the cloud test.
- **Repo hygiene:** keystore and passwords are git-ignored; Azure resource paths were masked before publishing test data.
- **Privacy:** UAT responses are confidential under the Data Privacy Act of 2012 (RA 10173).

IN PLAIN WORDS

Everything travels in a locked envelope, the phone keeps your pass in a safe, and the server's master keys are never written into the code.

INSIGHTS

GCM mode adds authentication on top of encryption: the test suite checks that "tampering ciphertext fails AES-256-GCM authentication", so altered data is rejected rather than silently decrypted into garbage.

4.5 Injection prevention `prepared statements`

DEFINITION

SQL injection is when user input is treated as part of a database command. **Prepared statements** send the command and the data separately, so input can never become code.

WHY IT MATTERS HERE

Usernames, guesses, report messages and admin form fields all reach the database.

HOW WE APPLIED IT

64 PHP files on the live API use PDO `prepare()` with named parameters, e.g. `$pdo→prepare("DELETE FROM api_tokens WHERE token_hash = :h")`. The guess validator also accepts letters only (`NotLetters`).

IN PLAIN WORDS

The database gets the question and the answer in separate envelopes, so someone typing a command into the name box just gets a strange name, not a deleted table.

INSIGHTS

Injection is a long-standing entry on the OWASP Top 10. Validating on the phone is for user experience; the server's prepared statements are the real defence, because attackers can skip the app entirely.

4.6 Ledger integrity & auditing `hash chain · PoA · hourly check`

DEFINITION

Integrity means data can't be changed without detection. **Proof of Authority (PoA)** is a blockchain model where approved signers (here, the server) create blocks, instead of public mining.

WHY IT MATTERS HERE

KK and badges should not be editable by anyone, admins included. This is the study's core contribution.

HOW WE APPLIED IT

- Each reward is encrypted, hashed and signed (`kk_phase2_assemble_sign_poa`), then appended to the hash-linked chain under a lock so two writes can't collide.
- The admin Audit page lists the whole ledger, and an hourly whole-chain check shows a **Chain integrity** card.
- The phone only ever shows balances and status read from the API: no seed phrases, keys or gas fees (a project non-negotiable).

IN PLAIN WORDS

Every reward is written in ink in a numbered, fingerprinted book. If anyone erases a line, the hourly check spots it.

INSIGHTS

Why PoA instead of a public chain like Ethereum? No gas fees per reward, instant confirmation, and no player wallets to lose, while still keeping the tamper-evidence that the study needs. secp256k1 keys keep the door open to a Polygon-compatible chain later.

Panel might ask: "Can an admin give themselves KK?" They could edit the database, but not the chain; the receipt would be missing or the hashes would break, and the integrity check would flag it.

UNIT 5

Cloud computing

Kusina Kode runs on Microsoft Azure in the `kusina-kode` resource group (Southeast Asia). This unit maps each service to the concept it demonstrates and to the stress-test evidence.

> **Review from past terms:** modules 5.0a to 5.0c recap the cloud basics you studied before (definition, models, virtualization, scaling, availability, shared responsibility, cost). Modules 5.1 to 5.6 then show how Kusina Kode uses them.

5.0a What cloud computing is `NIST definition · deployment models`

DEFINITION

NIST SP 800-145 defines cloud computing as on-demand network access to a **shared pool** of configurable computing resources (servers, storage, networks, applications) that can be provisioned and released quickly with minimal management effort.

5 CHARACTERISTICS

- **On-demand self-service**: create a server yourself, no ticket to a person.
- **Broad network access**: reached over the internet from any device.
- **Resource pooling**: many customers share the provider's hardware (multi-tenancy).
- **Rapid elasticity**: add or remove capacity quickly.
- **Measured service**: you pay for what you use, metered.

DEPLOYMENT MODELS

- **Public cloud**: shared provider infrastructure (Azure, AWS, Google Cloud).
- **Private cloud**: infrastructure for one organization only.
- **Community cloud**: shared by organizations with common needs.
- **Hybrid cloud**: public and private combined.

Kusina Kode runs on the **public cloud** (Microsoft Azure). Note: the manuscript's "hybrid deployment model" means a mix of **service models** (IaaS and PaaS), not a hybrid cloud.

IN PLAIN WORDS

Renting a kitchen by the hour instead of building one: you get it when you need it, share the building with others, and pay for the hours you cook.

Panel might ask: "Is your system on a hybrid cloud?" No. It is on the public cloud. "Hybrid" in Chapter 3 refers to using two service models, IaaS for the API and PaaS for the console and data.

5.0b How the cloud runs

`virtualization · regions · VMs vs containers vs serverless`

VIRTUALIZATION

A **hypervisor** splits one physical server into many isolated **virtual machines**, each with its own operating system. This is what makes resource pooling possible.

COMPUTE OPTIONS

- **Virtual machine (IaaS)**: a full computer you manage, OS included. Ours: the API VM.
- **Container**: packages an app with its libraries and shares the host OS kernel; lighter than a VM (Docker, Kubernetes). Not used by Kusina Kode.
- **Platform service (PaaS)**: you deploy code, the provider runs the server. Ours: App Service for the console.
- **Serverless (FaaS)**: functions that run on events and bill per execution (Azure Functions). Not used.

REGIONS AND ZONES

A **region** is a geographic area with data centers (ours: Southeast Asia). An **availability zone** is a separate data center within a region; spreading copies across zones survives a data-center failure.

Kusina Kode runs one VM in one region, so the VM is a **single point of failure**; data survived the September 25 restart, but there is no second copy of the API running.

IN PLAIN WORDS

One big building (server) divided into private apartments (VMs). Containers are rooms that share the same plumbing. Serverless is a vending machine: it runs only when someone presses a button.

Panel might ask: "Why not containers or serverless?" The ledger needs a private folder on disk and scheduled jobs, which a VM gives directly; containers or functions would need extra storage and scheduling services. It is a valid future option.

5.0c Running well in the cloud

`scaling · availability · shared responsibility · cost`

SCALABILITY VS ELASTICITY

Scalability is the ability to handle more load by adding resources: **vertical** (a bigger machine or tier) or **horizontal** (more machines behind a load balancer). **Elasticity** is doing it **automatically** as demand rises and falls (auto-scaling).

Kusina Kode: the stress test showed the Basic database tier is the limit, so the next step is vertical scaling of the database; no auto-scaling is set up.

AVAILABILITY AND SLA

Availability is the share of time a service is up. A **Service Level Agreement** is the provider's promise, often written in "nines": 99.9% allows about 8.8 hours of downtime a year, 99.99% about 53 minutes. Redundancy (more copies, more zones) raises availability.

SHARED RESPONSIBILITY

Security is split between provider and customer. The provider always secures the **physical** data center and hardware. With **IaaS** you secure the OS, patches, network rules, and app (we patched the VM's 25 pending updates on September 25). With **PaaS** the provider also patches the OS and runtime; you secure your code, data, and access.

COST MODEL

Cloud turns **capital expense** (buying servers) into **operating expense** (paying monthly for use). Costs depend on size and tier: a bigger database tier costs more per month, which is the trade-off of scaling.

MONITORING

Metrics (CPU, memory, database load, response time) and logs show health and limits. We used Azure Monitor during the stress test: database at 91%, VM processor at about 12%.

Panel might ask: "How would you handle 1,000 players?" Raise the database tier first (the measured bottleneck), then add a second API VM behind a load balancer and move the ledger's files to shared storage. That is horizontal scaling.

5.1 Cloud service models `IaaS · PaaS · SaaS`

DEFINITION

IaaS rents raw servers you manage yourself. **PaaS** rents a managed platform where the provider runs the server and you supply the app or data. **SaaS** is finished software you just use.

WHY IT MATTERS HERE

Each part of the system has different needs, so it uses a different model.

HOW WE APPLIED IT

PART	AZURE SERVICE	MODEL
PHP REST API + reward chain	Virtual Machine `vm-kusinakode-api`	IaaS
Database (36 tables)	Azure SQL `sql-kusinakode/kusinakode`, Basic tier	PaaS
Admin console	App Service `app-kusinakode-admin2`, B1	PaaS
Uploaded pictures	Blob Storage `stkusinakode/media`	PaaS (storage)
Admin sign-in	Microsoft Entra ID	SaaS identity

IN PLAIN WORDS

We rent a whole kitchen for the API (and run it ourselves), but rent ready-made services for the database, website and photo storage.

INSIGHTS

The API is on a VM because the chain needs a private folder on disk and scheduled jobs (cron), which a full server allows. The database and console are PaaS so Azure handles patches and backups.

5.2 Compute: the API virtual machine `vm-kusinakode-api`

DEFINITION

A virtual machine is a software-defined computer in the provider's data centre, with its own OS, disk and network address.

WHY IT MATTERS HERE

It runs everything the phone talks to: `api.kusinakode.com/kusinakode/REST/`.

HOW WE APPLIED IT

- A Linux VM serving the PHP API from `/var/www/kusinakode`, with the chain in `/var/lib/kusinakode/chain`.
- **Scheduled jobs:** `settle_pending_cron.sh` every 15 minutes (finishes stuck rewards) and a receipt-cache refresh every minute.
- **Operations:** changes are applied with backups first (`*.bak-YYYYMMDD`) through Azure's Run Command.

IN PLAIN WORDS

A computer in Microsoft's building that stays on 24/7 and answers the app's requests.

INSIGHTS

Stress test: at 40 simultaneous players the VM's CPU stayed at or under about 12%. The server is not the bottleneck.

5.3 Managed relational database `Azure SQL · DTU`

DEFINITION

A database service where the provider runs the database engine. Capacity is sold in tiers; Azure's **DTU** (Database Transaction Unit) measures a blend of CPU, memory and disk work.

WHY IT MATTERS HERE

Every level list, leaderboard and reward lookup hits this database.

HOW WE APPLIED IT

Azure SQL Database `kusinakode` on the **Basic** tier, reached by the API's PHP code and Kyla's console. Firewall rules allow only known IPs; administrators sign in with Entra ID or the SQL admin login.

IN PLAIN WORDS

> A filing cabinet Microsoft looks after, where every record of the game lives.

INSIGHTS

Stress test: database load rose from 7% (5 players) to **91% peak at 40 players**, while the VM sat near 10%. The database tier is the system's capacity limit. The fix is **vertical scaling** (Basic → Standard), a settings change that costs more per month.

Panel might ask: "How many users can it handle?" Up to 40 at once with zero errors (average response 1.6 s). Past about 50, the Basic database would start queuing; raising its tier is a configuration change.

5.4 Object storage `Blob Storage`

DEFINITION

Storage for files ("blobs") addressed by URL, cheaper and simpler than keeping files on a server's disk.

WHY IT MATTERS HERE

Admins upload dish, equipment and ingredient pictures that the console and app must show.

HOW WE APPLIED IT

Storage account `stkusinakode`, container `media`, folders `levels/` and `equipment/`. Files are readable by direct URL, but the container can't be listed anonymously.

IN PLAIN WORDS

> An online photo album: each picture has its own link, but strangers can't browse the album.

INSIGHTS

Keeping pictures out of the database keeps the database small and fast, which matters given that the database is the bottleneck (5.3).

5.5 Identity, domains & certificates `Entra · DNS · TLS`

DEFINITION

Identity as a service handles sign-in centrally. **DNS** maps names like `api.kusinakode.com` to servers, and **TLS certificates** prove a site is genuine and encrypt traffic.

WHY IT MATTERS HERE

Players and admins need memorable, trusted addresses, and admin sign-in needs strong protection.

HOW WE APPLIED IT

- `api.kusinakode.com` → API VM. The app first used a hard-coded campus network IP (D-19), then the Azure VM's IP, and from 1.16 this name.
- `admin.kusinakode.com` → App Service, with Microsoft Entra sign-in for admins.
- Certificates from Let's Encrypt on the VM, renewed automatically by certbot.

IN PLAIN WORDS

The system has proper addresses with a padlock, and admins log in with their Microsoft account.

INSIGHTS

Using a domain name instead of an IP means the server can move or be replaced without releasing a new app; only the DNS record changes.

5.6 Monitoring, performance & scaling

`Azure Monitor · stress test`

DEFINITION

Monitoring collects metrics (CPU, memory, response time). **Stress testing** pushes a system past normal load to find its limits. **Scaling** adds capacity: vertically (a bigger machine or tier) or horizontally (more machines).

WHY IT MATTERS HERE

The study must show the system works for real users, not just on one developer's phone.

HOW WE APPLIED IT

TEST	RESULT
API, 5 → 40 players at once	0 errors · 0.25 s → 1.6 s average
Database load (Azure Monitor)	peak 91% DTU at 40 players
API VM CPU	≤ ~12%
Phone (vivo V17 Pro), 22 min of play	0 crashes · memory flat 146–153 MB
Cold start	0.7 s phone · 2.6 s emulator
QA Round 2, Apache JMeter (19 Oct)	400 requests, 0 errors · 1.33 s average
Idle server, first request	5.4 s, then ~0.23 s

IN PLAIN WORDS

We pretended 40 people played at once and watched the gauges. Nothing broke; the database was the part working hardest.

INSIGHTS

Measuring, not guessing, found the real limit (the database, not the server) and two real fixes: the 1.26 startup change and the 1.27 image and animation changes. It also showed the Game Map is graphics-bound on a mid-range phone. The full workbook is `docs/testing/stress-mobile-2026-10-05/`.

Sources: manuscript v2.30 (October 20, 2026), the Kusina Kode app repository (Kotlin, release 1.31), the KusinaKode-Web repository (ASP.NET + PHP API), the live API on `vm-kusinakode-api` (read-only

inspection, 8 Oct 2026), `docs/testing/defects.csv`, and the 5 Oct 2026 stress test workbook.

UNIT 6

System diagrams

A refresher on each kind of diagram in the paper (what it is for, what every shape means, and how to read it), followed by our own diagram and a walk-through. Everything was checked against the code and the live system on 15 Oct 2026.

6.0 How to read any diagram `the 4 questions`

WHY DIAGRAMS

A diagram is a **model**: it shows one view of the system and leaves the rest out on purpose. Each type answers a different question, so the panel will ask about each one differently.

PICK THE RIGHT ONE

QUESTION	DIAGRAM	FAMILY
Where does the **data** go, and where is it kept?	Data flow diagram (DFD)	Structured analysis
How is the **database** organised?	Entity relationship diagram (ERD)	Data modelling
Who does **which step** in one scenario, in order?	Process flow (swimlane flowchart)	Flowchart (ANSI/ISO 5807)
How does data move through **stages and jobs**?	Data pipeline	Data engineering
Who uses the system, and for **what**?	Use case diagram	UML (behaviour)
What are the **parts**, and how do they connect?	System architecture	Architecture
What are **all the paths** one user can take?	Activity diagram	UML (behaviour)
Where does it **run**, and how is it **protected**?	Cloud and cybersecurity architecture	Architecture
What went **in**, what did we **do**, what came **out**?	Conceptual framework (IPO)	Research

THE 4 QUESTIONS

- **What is the scope?** Read the title and the boundary first: the whole system, one process, or one scenario.

- **What are the shapes?** Every notation has a small set of symbols. Learn them below; a shape always means the same thing within one diagram type.
- **Where do I start?** At the start node, the actor, or the outside entity. Then follow the arrows.
- **What does a line mean?** It is different per type: data moving (DFD), a relationship (ERD), the next step (flowcharts), "uses" (use case), or a network call (architecture).

IN PLAIN WORDS

Each diagram is a different photo of the same house: the floor plan, the plumbing, the wiring, the guest list. None of them is the whole house, and each one is drawn with its own symbols.

PANEL MIGHT ASK

Why so many diagrams? Each answers a different question. The ERD cannot show the order of steps, and the activity diagram cannot show the tables.

Process flow vs activity diagram? A process flow follows one scenario across the people and systems that handle it (swimlanes). An activity diagram (UML) shows every path one user can take, including parallel steps (fork and join).

6.0b How to present any diagram `the 5-step walk-through`

THE RULE

The panel looks at the diagram, not at you. Your job is to **guide their eyes**: tell them where to look, in what order, and what it means. Never read every box aloud.

THE 5 STEPS

1. **Name it and its purpose** (one sentence): "This is our Level 1 data flow diagram. It shows where data moves and where it is stored."
2. **Teach the notation** only if needed (one sentence): "Rounded boxes are processes, open boxes are data stores."
3. **Point to the start**: the outside entity, the actor, or the start node. Use the laser or your hand.
4. **Follow one main path** to its end, naming each hand-off: "the app sends the guess to the API, which records it…". One path, not all of them.
5. **Land on the takeaway** (one sentence): what this diagram proves about the system.

IN PLAIN WORDS

Be a tour guide in a museum: "this painting, look here first, then follow this line, and this is why it matters." Thirty to forty seconds per diagram.

WHEN THEY ASK ABOUT ONE BOX

- Point to it, say what it is, and connect it back to the main path.
- If it is detail you do not know, say which document holds it: "That is in Appendix B, the full DFD."
- Keep the diagram on screen while answering. Do not flip slides looking for it.

Panel might ask: "Why are there so many diagrams?" Each answers a different question (table above): data, database, one scenario, stages, users, parts, paths, hosting, protection, research model. Together they describe one system, and their names and IDs match.

6.1 Data flow diagram (DFD) `Gane & Sarson · Levels 0, 1, 2`

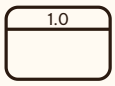
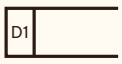
WHAT IT IS

A DFD shows how **data moves** through a system: where it comes from, which process changes it, and where it is stored. It does **not** show order, timing or decisions; that is what the flowcharts are for.

It is drawn in **levels**. **Level 0** (context diagram) is the whole system as one process. **Level 1** opens that box into the main processes. **Level 2**

opens one Level 1 process further (ours explodes 4.0 Process Rewards into 4.1 to 4.5).

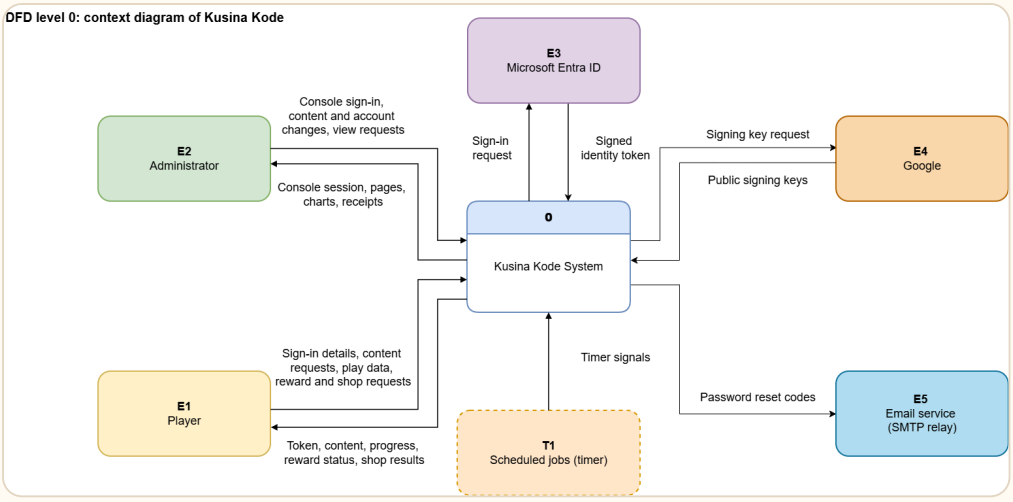
SYMBOLS

SYMBOL	NAME	WHAT IT MEANS
	**External entity**	A person or outside system that sends or receives data but is not part of the system (E1 Player, E3 Microsoft Entra ID). Also called a source or sink.
	**Process**	Something that **changes** data. Numbered by level: 1.0 at Level 1, 4.1 at Level 2. Named with a verb: "Authenticate & Authorize".
	**Data store**	Data at rest: a table group, a file or a folder (D1 Accounts, D5 Reward Ledger). Named with a noun.
	**Data flow**	Data in motion, labelled with a noun: "Credentials", "Reward status & TxHash". The arrow points where the data goes.
	**Two-way flow**	Data goes both ways (read and write). Clearer when drawn as two one-way arrows, each with its own label.
	**Timer (our convention)**	T1 Scheduled Jobs, drawn dashed: the clock that starts the settle, verify and refresh jobs.

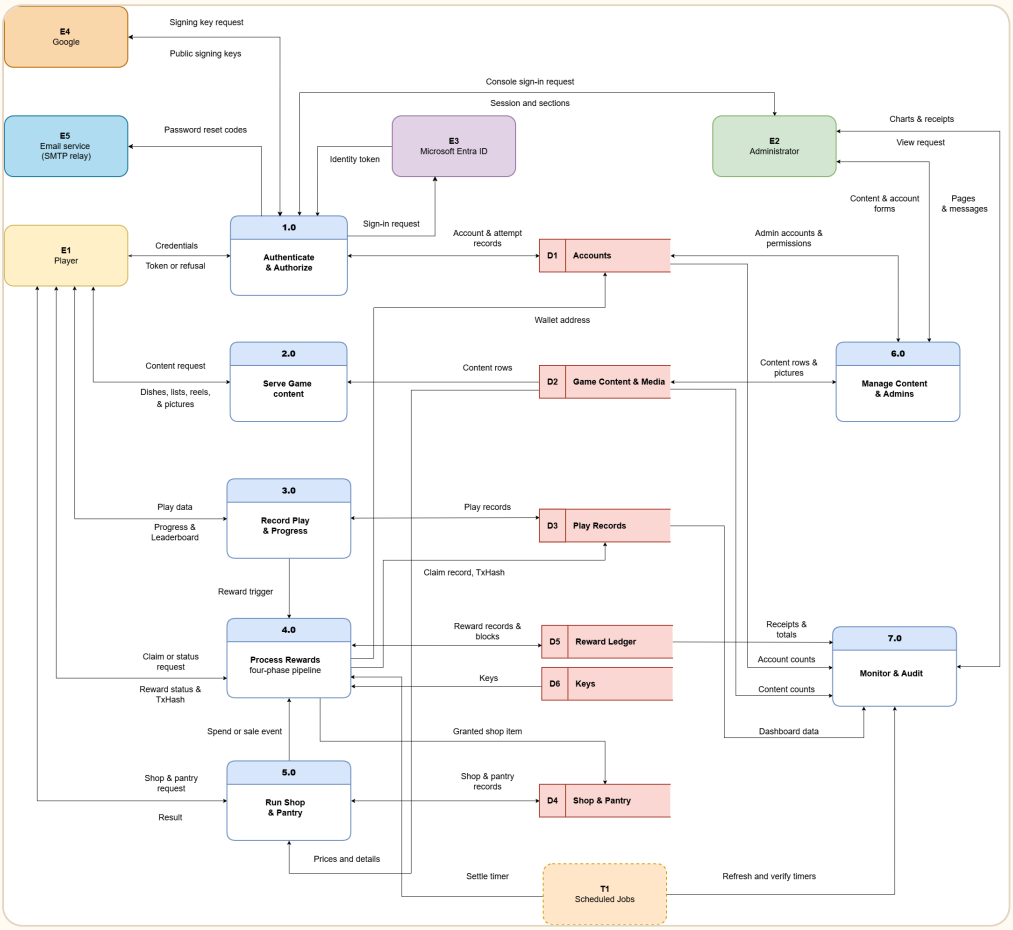
RULES TO CHECK

- Every process has at least one input **and** one output (no "black holes" or "miracles").
- Data never moves store to store, entity to store, or entity to entity without a process in between.
- **Balancing:** the flows into and out of a Level 1 process must match its Level 2 diagram.
- Labels are nouns (what the data is), never verbs (that is the process's job).
- Other notation you may see: Yourdon/DeMarco draws processes as circles and stores as two parallel lines. Same meaning.

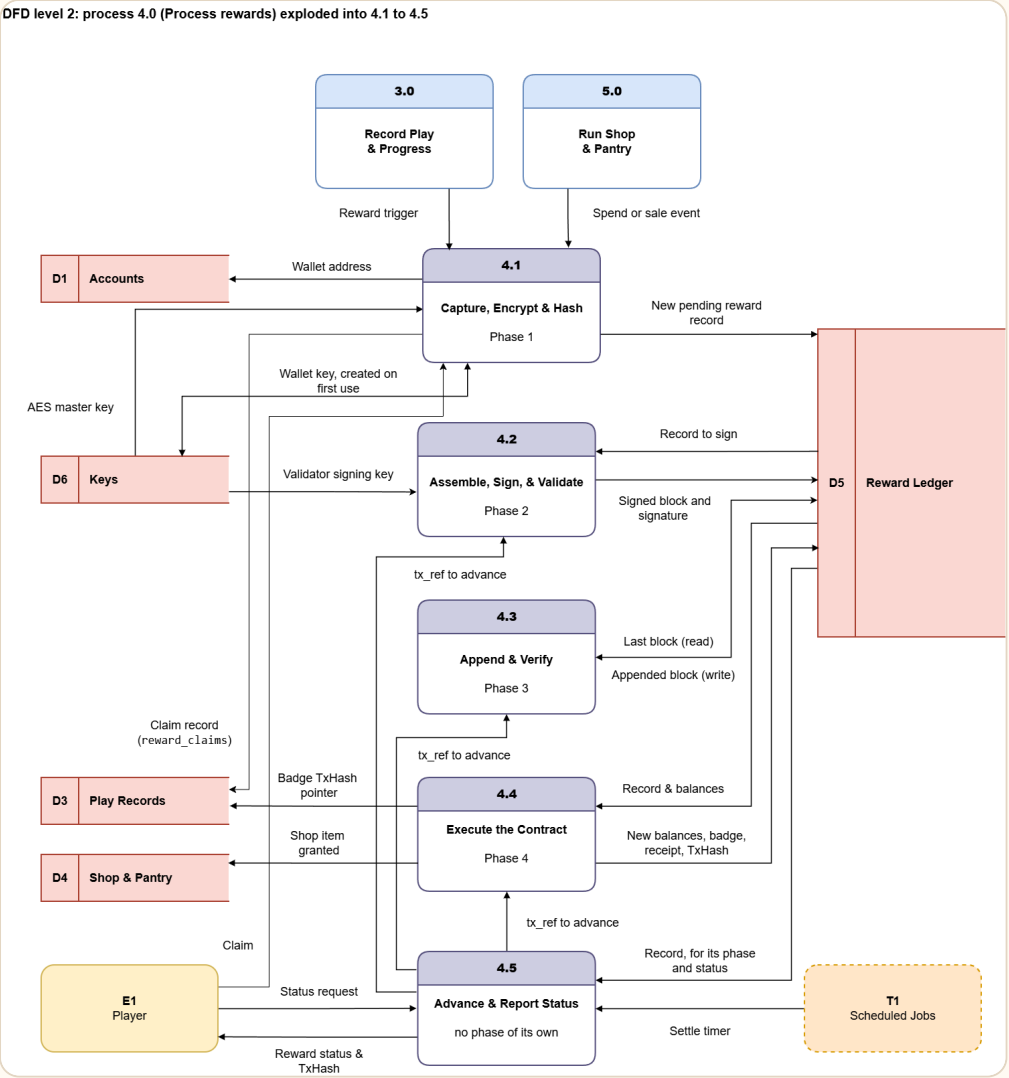
OUR DIAGRAMS



Level 0: the whole system as one process (0), with the five outside parties and the timer.



Level 1: seven processes (1.0 to 7.0) and six data stores (D1 to D6).



Level 2: process 4.0 Process Rewards exploded into 4.1 to 4.5.

HOW TO READ OURS

- **Level 0:** the Player (E1) and the Administrator (E2) send requests and get results back. Microsoft Entra ID (E3) signs admins in; Google (E4) gives the public keys that prove a player's Google token is real; the Email service (E5) sends reset codes; the timer (T1) starts the scheduled jobs.
- **Level 1:** 1.0 Authenticate, 2.0 Serve game content, 3.0 Record play, 4.0 Process rewards, 5.0 Run shop and pantry, 6.0 Manage content and admins, 7.0 Monitor and audit. The stores are D1 Accounts, D2 Game content and media, D3 Play records, D4 Shop and pantry, D5 Reward ledger, D6 Keys.
- **Level 2:** the four reward phases (4.1 to 4.4) and 4.5, which moves a record to its next phase each time the app asks for its status (or when the 15-minute settle job runs).

IN PLAIN WORDS

Follow the paperwork, not the people: who hands in which form, which desk works on it, and which filing cabinet it ends up in.

PANEL MIGHT ASK

Why is the Scheduler drawn at all? Some processes start on a clock, not on a user: settling rewards every 15 minutes, verifying the chain every hour, refreshing the receipt copy every minute. T1 shows where those start.

Where are the reports? The reports feature is turned off on the adviser's advice, so its table and flows are left out.

HOW TO PRESENT IT TO THE PANEL

1. Start at **Level 0**: point to the one process in the middle and the five outside parties around it.
2. Switch to **Level 1**: point to the seven processes and the six data stores (D1 to D6).
3. Follow one path: Player → 3.0 Record play → D3 Play records → 4.0 Process rewards → D5 Reward ledger.
4. Show **Level 2** as "4.0 opened up" into 4.1 to 4.5, and say it balances with Level 1.

Say (about 40 seconds): This is our data flow diagram. Level 0 shows the whole system as one process with its five outside parties, such as the player, the administrator, and Microsoft Entra ID. Level 1 opens it into seven processes and six data stores. Follow a play: the player's guess goes to Record play, is stored in Play records, and a first solve goes to Process rewards, which writes to the reward ledger. Level 2 opens Process rewards into its five steps, and its inputs and outputs match Level 1.

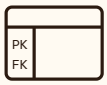
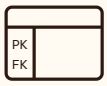
Avoid: reading every label; calling arrows "steps" (a DFD has no order); forgetting to say the levels balance.

6.2 Entity relationship diagram (ERD) `crow's foot · 35 tables`

WHAT IT IS

An ERD shows the **database design**: each table (entity), its columns (attributes), its keys, and how tables relate. Ours uses **crow's foot** notation and is the physical model, so it uses the real table and column names from Azure SQL.

SYMBOLS

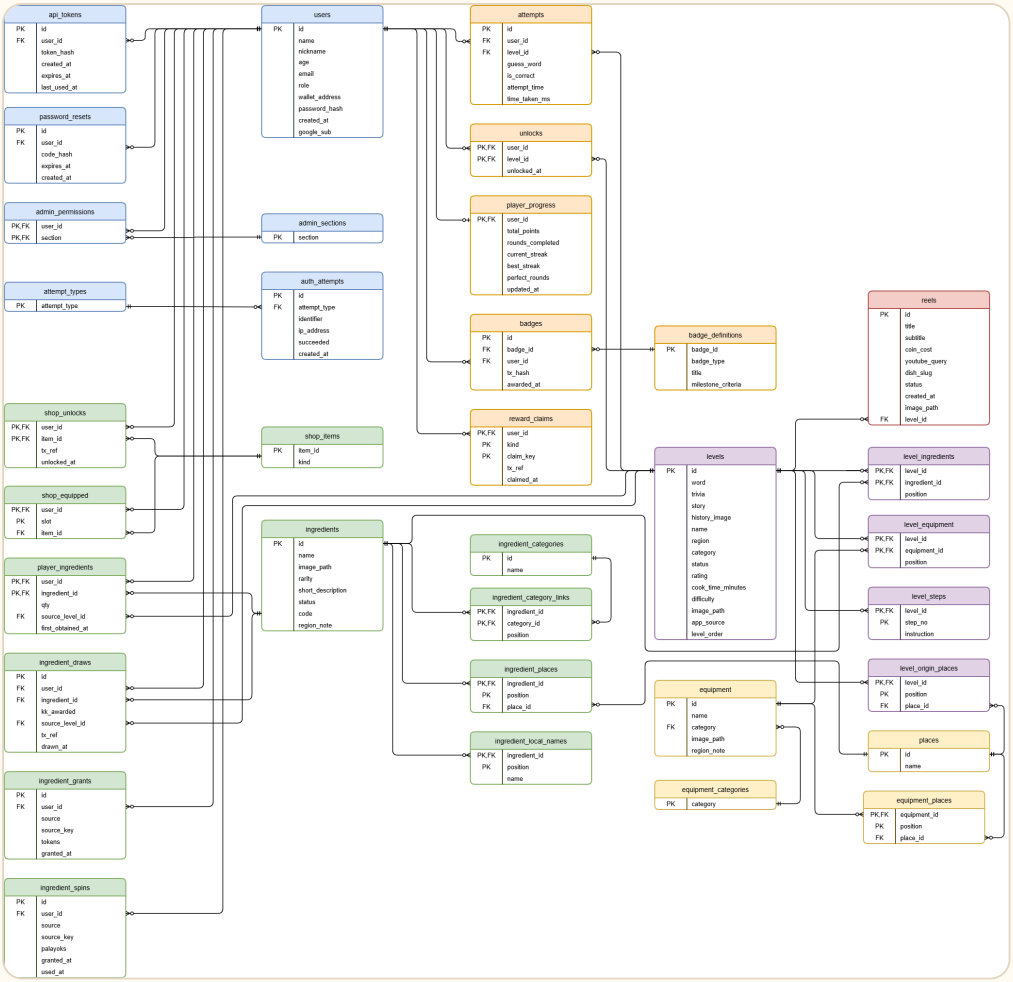
SYMBOL	NAME	WHAT IT MEANS
	**Entity (table)**	One table. The header is its name; each row is a column.
	**PK / FK**	**PK** (primary key) uniquely identifies a row. **FK** (foreign key) points to another table's PK. "PK,FK" means the column is both, as in a junction table.
	**Exactly one**	Two bars: one and only one (mandatory).
	**Zero or one**	Circle and bar: optional, at most one.
	**One or many**	Bar and crow's foot: at least one.
	**Zero or many**	Circle and crow's foot: any number, including none.

HOW TO READ A LINE

Read each end from the table on the **other** side. `users` ||——o< `attempts` says: one attempt belongs to exactly one user, and one user has zero or many attempts.

A **many-to-many** relationship cannot be stored directly, so it goes through a **junction table** whose key is both FKs: `level_ingredients` (level_id, ingredient_id) links dishes to ingredients.

OUR DIAGRAM



All 35 tables, colour-coded by area. Checked against the Azure SQL schema on 15 Oct 2026: every table and column matches.

- **Blue, accounts (7):** `users`, `api_tokens`, `password_resets`, `auth_attempts` and `attempt_types` (the lockout), `admin_permissions` and `admin_sections`.
- **Orange, play and rewards (6):** `attempts`, `unlocks`, `player_progress`, `badges` and `badge_definitions`, `reward_claims` (the "only once" rule for rewards).
- **Green, shop, pantry and ingredients (12):** `shop_items`, `shop_unlocks`, `shop_equipped`, the four pantry tables, `ingredients` and its categories, places and local names.
- **Purple, dishes (5):** `levels` and its child tables for ingredients, equipment, steps and places of origin.
- **Yellow and red:** the equipment catalog and `places`; `reels` (linked to a dish by `level_id`).

IN PLAIN WORDS

A set of spreadsheets that point at each other by ID, so each fact is written once: change a dish's name in one row and every player sees it.

PANEL MIGHT ASK

Is it normalized? Yes, to third normal form. On 12 to 13 Oct, lists stored as comma-separated text (a dish's ingredients, an admin's sections) were moved into child tables such as `level_ingredients` and `admin_permissions`.

Where is the blockchain? Not in SQL. The ledger lives in files on the API VM (`blocks.jsonl` and the receipts). The database keeps only pointers such as `badges.tx_hash` and `users.wallet_address`.

Why is `reports` missing? The table still exists, but the feature is hidden in the app and console on the adviser's advice, so it is left out of the ERD.

HOW TO PRESENT IT TO THE PANEL

1. Name the colour groups first (accounts, play and rewards, shop and pantry, dishes, catalogs).
2. Read **one relationship aloud** with crow's foot: users to attempts.
3. Point to one junction table (level_ingredients) to show many-to-many.
4. Say where the blockchain is: **not** in SQL, only pointers such as badges.tx_hash.

Say (about 40 seconds): This is our entity relationship diagram in crow's foot notation: 35 tables, colour-coded by area. For example, one user has zero or many attempts, and each attempt belongs to exactly one user. A dish has many ingredients and an ingredient is in many dishes, so a junction table, level_ingredients, links them. The database is normalized to third normal form. The reward ledger itself is not in SQL; the tables only keep pointers to it, such as the transaction hash of a badge.

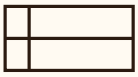
Avoid: listing all 35 tables; saying "the blockchain is in the database".

6.3 Process flow `swimlane flowchart · PF1 to PF4`

WHAT IT IS

A process flow is a **flowchart with swimlanes** (a cross-functional flowchart). It follows **one scenario** from start to end and shows which part of the system does each step. Ours have lanes for the Player or Administrator, the App or Console, the API, the Database and the Ledger.

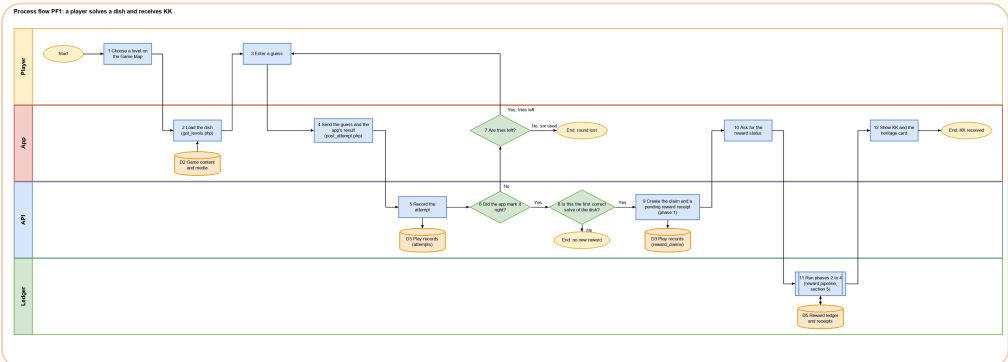
SYMBOLS

SYMBOL	NAME	WHAT IT MEANS
	**Terminator**	Start or End of the scenario. Every path ends in one: "End: KK received", "End: round lost".
	**Process step**	One action, numbered in order: "5 Record the attempt".
	**Decision**	A yes/no question. Each exit is labelled with its answer.
	**Data store**	Where the step reads or writes data (D3 Play records). Uses the same IDs as the DFD.
	**Predefined process**	A step explained in another diagram: "11 Run phases 2 to 4" is the reward pipeline (6.4).
	**Swimlane**	One row per actor or part of the system. When the arrow crosses a lane, the work is handed over.
	**Flow line**	The next step.

HOW TO READ IT

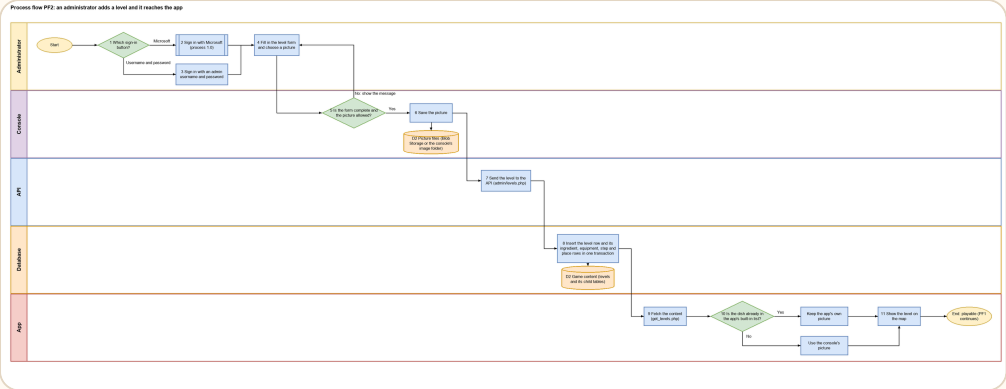
- Start at the Start oval and follow the numbers.
- Every time the line changes lane, say who hands what to whom ("the app sends the guess to the API").
- At each diamond, follow one answer to its End, then come back for the other.

OUR DIAGRAMS



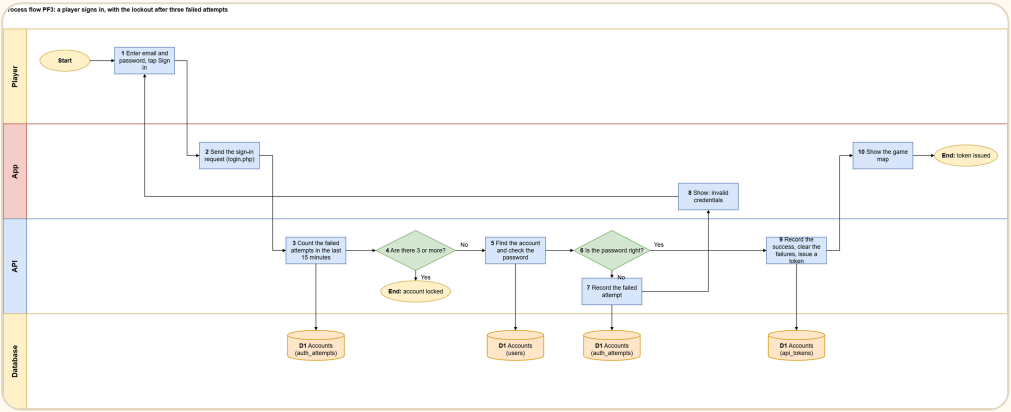
PF1: a player solves a dish and receives KK.

The app checks each guess and sends it with its result to `post_attempt.php`; the API records every attempt. On a correct first solve the API inserts the claim row and a pending receipt (Phase 1), and the remaining phases run as the app asks for the reward status.



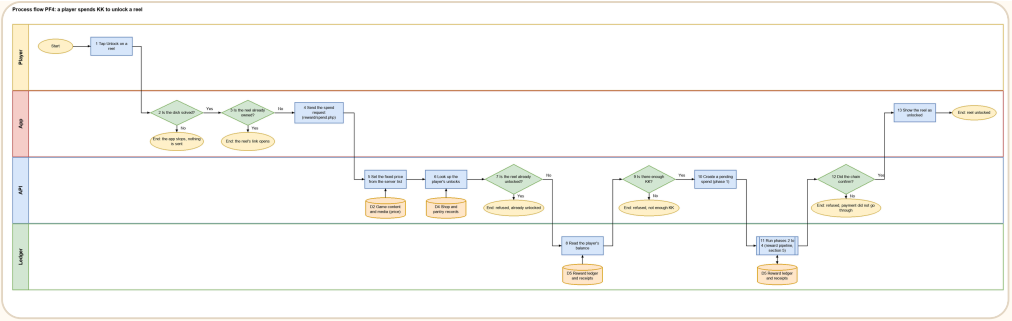
PF2: an administrator adds a level and it reaches the app.

Sign in (Microsoft or the emergency account), fill in the form, the console checks it and saves the picture, the API writes the level and its ingredient, equipment, step and place rows in one transaction, and the app shows it on the Game Map. The API checks that the account is an administrator; the Levels permission is enforced by the console hiding the tab.



PF3: a player signs in, with the lockout after three failed attempts.

The API first counts the account's failed attempts in the last 15 minutes. Three or more means locked (HTTP 429: "reset your password, or try again in 15 minutes"). Otherwise it checks the password; a failure is recorded, a success clears the failures and issues a token. The lock follows the account typed in, not the phone.



PF4: a player spends KK to unlock a reel.

The app stops early if the dish is unsolved or the reel is already owned. The API sets the price itself (the app cannot choose it), refuses a reel already unlocked, checks the balance, and runs all four reward phases in the same request, so the reel is only granted after the payment is confirmed.

IN PLAIN WORDS

A relay race drawn on paper: each lane is a runner, and the arrow shows exactly when the baton is passed.

PANEL MIGHT ASK

Why does PF4 finish in one request but PF1 does not? A spend must be paid before the reel is given, so the API runs all four phases before answering. A win only adds KK, so the app gets a pending receipt at once and the remaining phases run as it asks for the status.

HOW TO PRESENT IT TO THE PANEL

1. Pick **one** process flow (PF1 for players, PF2 for admins); have the others ready.
2. Point to the lanes first: Player, App, API, Database, Ledger.
3. Follow the numbered steps; say who hands what to whom each time the line changes lane.
4. At the main diamond, follow one answer to its End, then mention the other.

Say (about 40 seconds): This is the process flow for a player solving a dish. Each row is one part of the system. The player enters a guess, the app checks it and sends it to the API, and the API records every attempt in the database. If it is the first correct solve, the API records the claim and starts the reward pipeline, and the player receives KK with a receipt. If it was already solved, the round is recorded but no KK is paid.

Avoid: walking through all four flows; skipping the lane changes, which are the point of a swimlane chart.

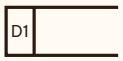
6.4 Data pipeline `transaction lifecycle · batch ETL`

WHAT IT IS

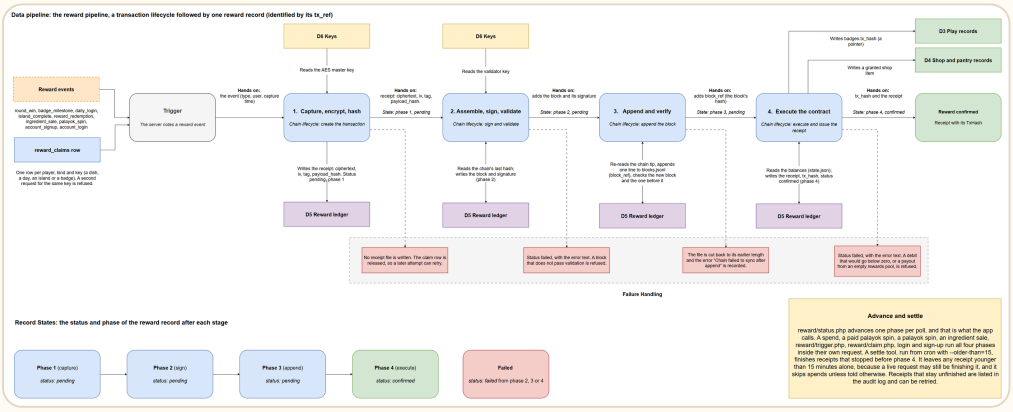
A data pipeline is a chain of **stages** that data passes through, where each stage takes the output of the one before. Two common kinds:

- **Transaction lifecycle** (event processing): one record moves through fixed phases and states, like our reward pipeline.
- **Batch ETL**: scheduled jobs **E**xtract data from a source, **T**ransform it (sort, count, check), **L**oad the result somewhere fast to read, and then **serve** it, like our reporting pipeline.

SYMBOLS

SYMBOL	NAME	WHAT IT MEANS
	**Stage**	One step of the pipeline, in order from left to right.
	**Data store**	Where a stage reads or writes (D5 Reward ledger, D6 Keys).
	Hand-off	The record or data passed to the next stage ("Hands on: tx_hash and the receipt").
	Failure path	Dashed: what happens if the stage fails.
	**Trigger**	What starts it: a request, or a schedule (cron: every minute, every hour, every 15 minutes).

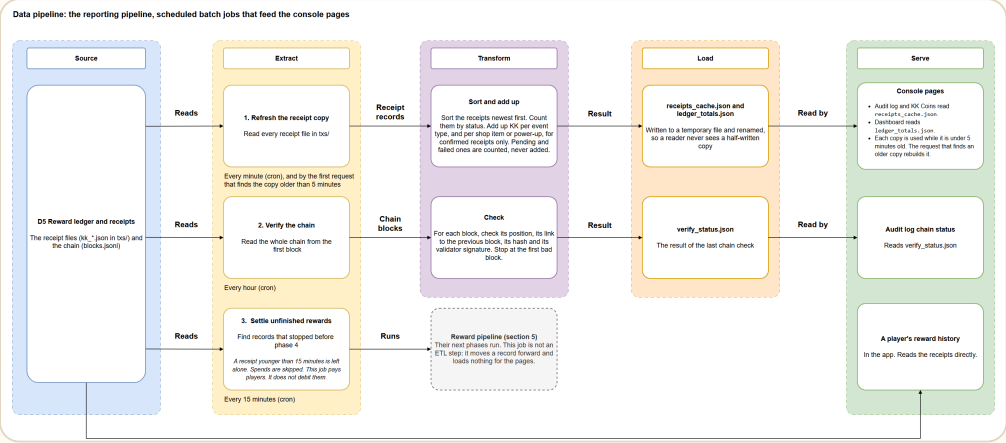
OUR DIAGRAMS



Reward pipeline: one reward record, followed by its `tx_ref`, through the four phases.

- **Phase 1, capture, encrypt, hash:** the event is sealed with AES-256-GCM and fingerprinted with SHA-256. State: pending.

- **Phase 2, assemble, sign, validate:** a block is built and signed with the validator's ECDSA key, and the PoA rule checks it.
- **Phase 3, append and verify:** the block is added to `blocks.jsonl`, linked to the one before.
- **Phase 4, execute the contract:** KKCoin and KKBadge rules update the balance, write the TxHash receipt, and grant a badge or shop item. State: confirmed.
- **Failures:** each phase has its own failure path (dashed); a failed record is kept and listed in the audit log. Phase 4 refuses a debit that would go below zero, or a payout when the rewards pool is empty.



Reporting pipeline: the scheduled jobs that feed the console.

- **Every minute:** read every receipt, sort and add up, and write `receipts_cache.json` and `ledger_totals.json` for the Audit log, KK Coins and Dashboard pages.
- **Every hour:** verify the whole chain (position, link, hash and signature of each block) and write `verify_status.json`.
- **Every 15 minutes:** settle rewards that stopped before Phase 4 (older than 15 minutes; spends are skipped).

IN PLAIN WORDS

The reward pipeline is a receipt going through four stamps. The reporting pipeline is the night clerk who adds up all the receipts so the manager's screen opens fast.

PANEL MIGHT ASK

Why a saved copy instead of reading the receipts live? During the stress test, opening every receipt file on each page load took 6 to 10 seconds. The copy rebuilt every minute brought it under 0.75 seconds.

Can the settle job pay twice? No. It skips records younger than 15 minutes (a live request may still be finishing them), and the claim row allows each reward only once.

HOW TO PRESENT IT TO THE PANEL

1. Show the **reward pipeline**: point to the four phases left to right.
2. Name the state change: pending after Phase 1, confirmed after Phase 4.
3. Point to one dashed failure path and say failed records are kept and listed.
4. Then the **reporting pipeline**: every minute, every hour, every 15 minutes.

Say (about 40 seconds): This is the reward pipeline. One reward moves through four phases: it is encrypted and hashed, then signed and validated under Proof-of-Authority, then appended to the chain, and finally the KKCoin or KKBadge rules apply it and issue a TxHash receipt. Each phase has a failure path, and a failed record is kept, not lost. The reporting pipeline runs on a schedule: every minute it summarizes receipts for the console, every hour it verifies the whole chain, and every 15 minutes it finishes stuck rewards.

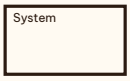
Avoid: mixing up the pipeline with the DFD; claiming the contract rules run on a public blockchain.

6.5 Use case diagram UML

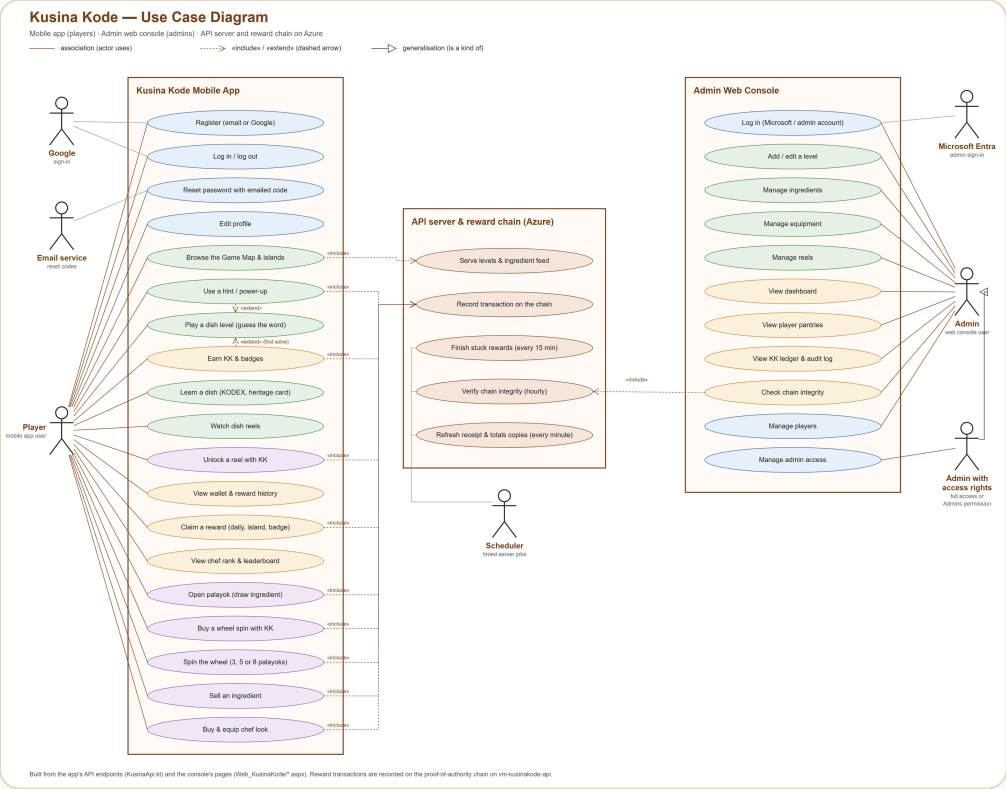
WHAT IT IS

A use case diagram shows **who** uses the system (actors) and **what goals** they can reach with it (use cases). It shows scope, not steps: the order of steps is in the activity diagrams.

SYMBOLS

SYMBOL	NAME	WHAT IT MEANS
	**Actor**	A role outside the system, not a specific person: Player, Admin. Outside systems can be actors too (Google, Microsoft Entra, the Scheduler).
	**Use case**	A goal written as a verb phrase: "Play a dish level".
	**System boundary**	The box around what the system does. Actors stay outside it.
	Association	Solid line: the actor takes part in that use case.
	«include» / «extend»	Dashed arrow. **«include»**: the base use case **always** does the other one (arrow points to the included one). **«extend»**: an **optional or conditional** add-on (arrow points to the base).
	**Generalisation**	Hollow triangle: "is a kind of". The child actor can do everything the parent can, and more.

OUR DIAGRAM



Three boundaries: the mobile app, the API server and reward chain, and the admin web console.

- **Player:** register and sign in, play a dish, use a hint, learn a dish, watch reels, claim rewards, spin the wheel, open palayoks, sell ingredients, buy chef looks.
- **«extend» examples:** *Use a hint / power-up* extends *Play a dish level* (optional); *Earn KK & badges* extends it too, because KK is paid only on the **first** solve.
- **«include» examples:** every KK action includes *Record transaction on the chain*; browsing the Game Map includes *Serve levels*.
- **Admin** manages levels, ingredients, equipment and reels and views the dashboard and ledger. **Admin with access rights** (generalisation) can also manage admin access.
- The **Scheduler** runs the timed jobs: finish stuck rewards (15 min), verify the chain (hourly), refresh the receipt copy (every minute).

IN PLAIN WORDS

A menu of what each kind of user can order from the system, without the recipe for how it is cooked.

PANEL MIGHT ASK

Why is Earn KK «extend» and not «include»? «Include» would mean every round pays KK. It doesn't: only the first correct solve of each dish does.

HOW TO PRESENT IT TO THE PANEL

1. Point to the three system boundaries (app, API and chain, console).

2. Point to the actors outside: Player, Admin, Admin with access rights, Scheduler, Google, Entra.
3. Read two or three player use cases, then one admin use case.
4. Explain one «extend» (Earn KK) and one «include» (Record transaction on the chain).

Say (about 40 seconds): This is our use case diagram. The actors outside the boxes are the player, the administrator, the administrator with access rights, and the scheduler. A player can register, play a dish, learn about it, claim rewards, and use the shop. An administrator manages levels, ingredients, equipment, and reels and views the ledger. Earning KK is drawn as an extension of playing, because only the first solve pays, while every KK action includes recording a transaction on the chain.

Avoid: describing steps in order (that is the activity diagram); reading all use cases.

6.6 System architecture `3 tiers`

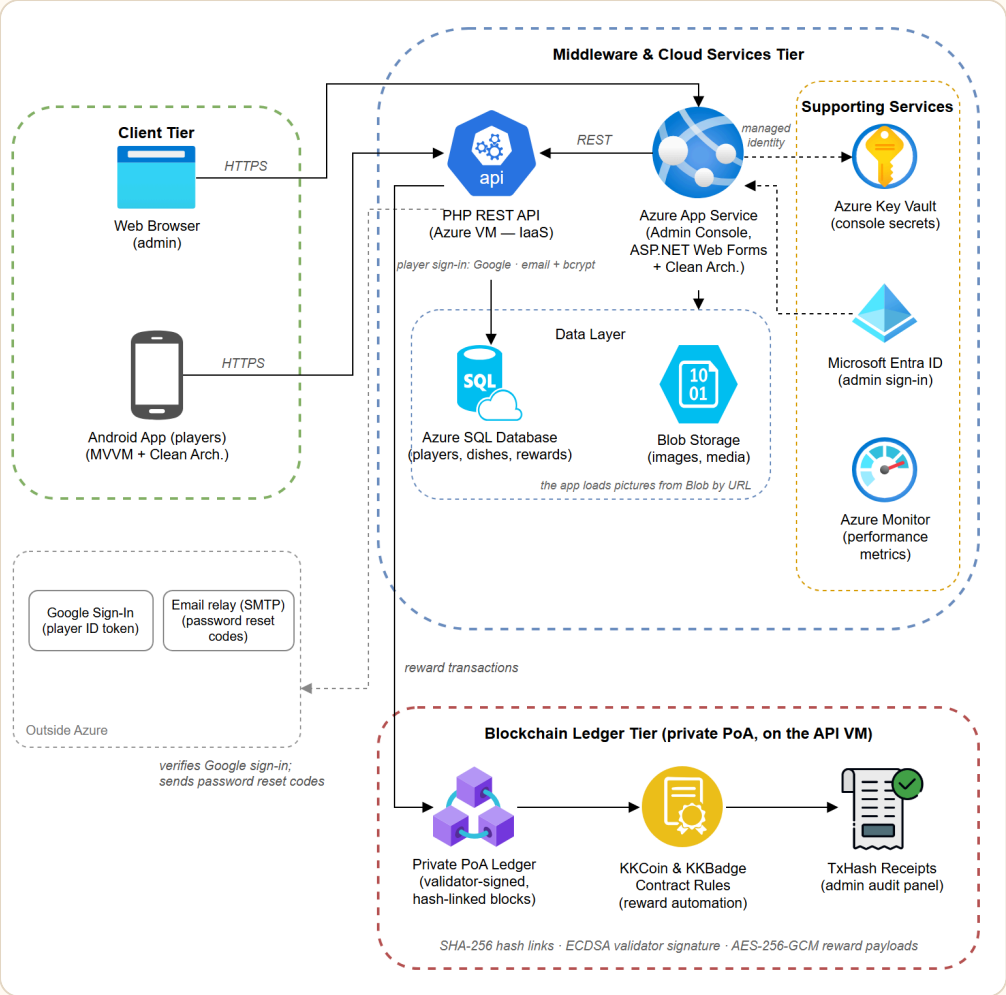
WHAT IT IS

A system architecture diagram shows the **main parts** of the system and how they **connect**, usually grouped into tiers (layers). Each tier has one job and talks to the tier next to it.

SYMBOLS

SYMBOL	NAME	WHAT IT MEANS
	**Tier / boundary**	A dashed group: one layer (Client, Middleware and Cloud Services, Blockchain Ledger) or "Outside Azure".
	**Component**	One part of the system, usually shown with its product icon (the API, Azure SQL, Key Vault).
	**Connector**	Who calls whom, labelled with the protocol or the data (HTTPS, REST, reward transactions). The arrow points from the caller.
	Dashed connector	A supporting link, such as a managed identity or a call to an outside service.

OUR DIAGRAM



Client tier, middleware and cloud services tier, and the blockchain ledger tier.

- **Client tier:** the admin's web browser and the Android app (MVVM + Clean Architecture), both over HTTPS.
- **Middleware and cloud services:** the PHP REST API on an Azure VM and the Admin Console on App Service (ASP.NET Web Forms + Clean Architecture); the data layer (Azure SQL, Blob Storage); supporting services (Key Vault through the console's managed identity, Entra ID for admin sign-in, Azure Monitor).
- **Outside Azure:** Google Sign-In (the API checks the player's ID token) and the email relay (password reset codes).
- **Blockchain ledger tier:** only the API sends reward transactions into it: the private PoA ledger, then the KKCoin and KKBadge contract rules, then the TxHash receipts.

IN PLAIN WORDS

The front counter (apps) takes orders, the kitchen (API and database) prepares them, and the cashier's sealed book (ledger) records every payment. Customers never write in the book themselves.

PANEL MIGHT ASK

Why separate tiers? Each tier can change without breaking the others. The database was normalized on 12 to 13 Oct without changing the app, because the API kept the same replies.

HOW TO PRESENT IT TO THE PANEL

1. Point to the three tiers, top to bottom.
2. Trace one request: Android app → HTTPS → PHP API on the VM → Azure SQL.
3. Point to the supporting services: Key Vault, Entra ID, Monitor, and outside Azure: Google and email.
4. End at the ledger tier: only the API writes to it.

Say (about 40 seconds): This is our system architecture in three tiers. In the client tier, players use the Android app and admins use a web browser. Both call the middleware tier over HTTPS: the PHP REST API on an Azure virtual machine and the admin console on App Service, with Azure SQL and Blob Storage for data. The blockchain ledger tier is reached only by the API, which records every reward and issues its TxHash receipt. Players never write to the ledger themselves.

Avoid: confusing this with the cloud diagram (this one is about parts and calls, not Azure containers).

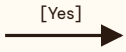
6.7 Activity diagram

`UML · player and administrator`

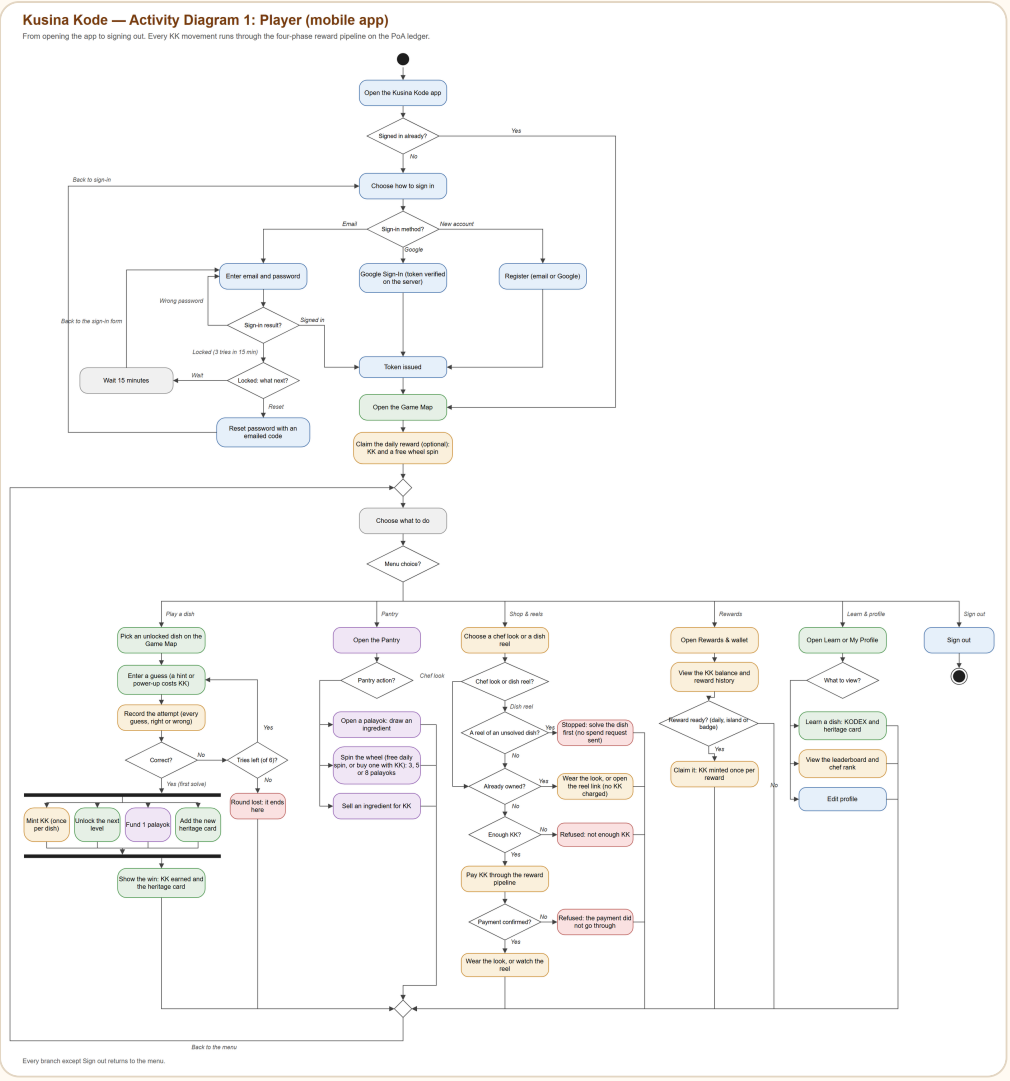
WHAT IT IS

An activity diagram (UML) shows **every path** a user can take through a feature: the actions, the decisions, the loops, and the steps that happen together. Think of it as a flowchart with extra UML rules for parallel work.

SYMBOLS

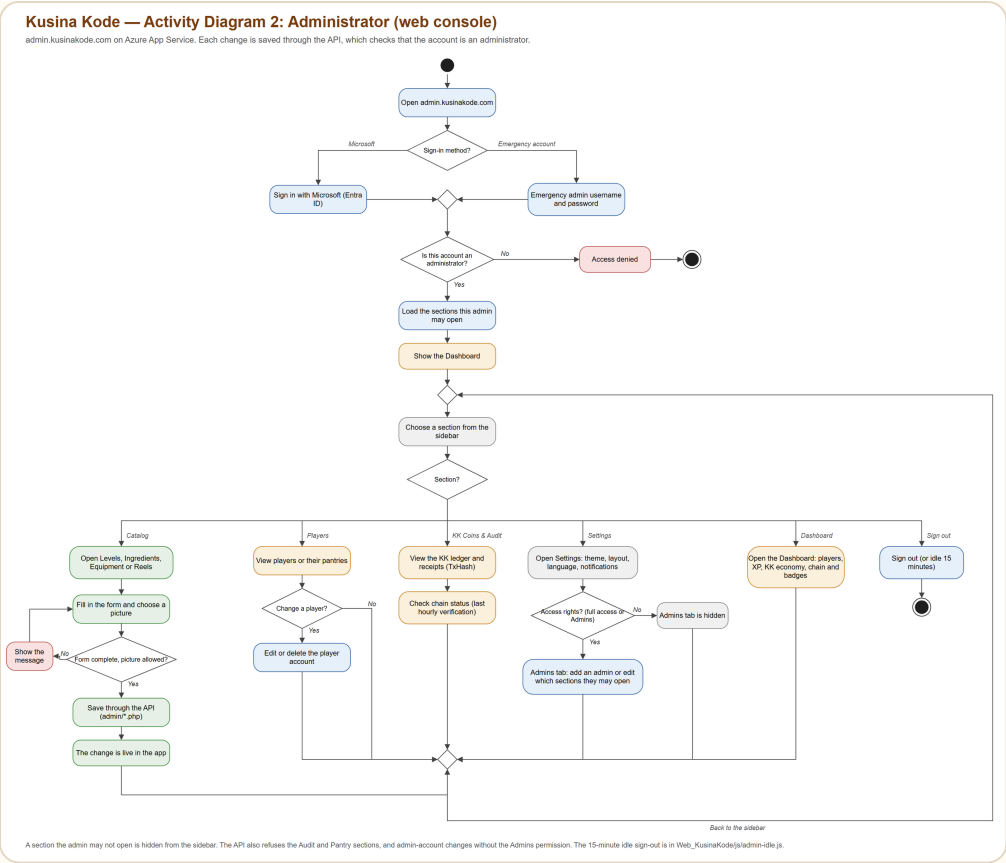
SYMBOL	NAME	WHAT IT MEANS
	**Initial node**	Where the activity starts. Only one.
	**Activity final**	Where it ends (bullseye).
	**Action**	One step, in a rounded box: "Enter a guess".
	**Decision**	One way in, several ways out; each exit has a guard.
	**Merge**	Several ways in, one way out: the branches meet again (the small diamond before "Choose what to do").
	**Fork / join**	Thick bar. A **fork** starts steps that all happen; a **join** waits until all of them are done (mint KK, unlock the next level, fund a palayok, add the heritage card).
	**Guard**	The condition on an exit, such as [Yes], [No] or [Locked]. Ours are written in italics beside the line.

OUR DIAGRAMS



Player (mobile app): from opening the app to signing out.

- **Sign-in:** email, Google or a new account. A wrong password loops back; after 3 tries in 15 minutes the account is locked, and the player either **waits 15 minutes** or **resets the password** with an emailed code.
- **Play a dish:** every guess is recorded, right or wrong. A wrong guess asks "Tries left (of 6)?"; the first correct solve forks into minting KK, unlocking the next level, funding one palayok and adding the heritage card.
- **Shop and reels:** the first question is *chef look or dish reel?* Only a reel can belong to an unsolved dish, which stops the purchase (no spend is sent). Then both meet at *Already owned?*: an owned look is worn and an owned reel opens its link, with no KK charged. Otherwise the KK check and the payment follow.
- Every branch except Sign out returns to the menu.



Administrator (web console): from signing in to signing out.

- Sign in with Microsoft (Entra ID) or the emergency account; a non-admin account is refused.
- The sidebar shows only the sections this admin may open: the catalogs, players, KK coins and audit, settings, and the dashboard. The Admins tab appears only with the Admins permission.
- Sign out, or the console signs out after 15 minutes idle.

IN PLAIN WORDS

A "choose your own adventure" map of the app: every choice the user can make, and where each one leads.

PANEL MIGHT ASK

Why a fork bar after a correct guess? The four rewards of a first solve are independent and all must happen; a fork and join shows "all of these" better than four boxes in a row.

HOW TO PRESENT IT TO THE PANEL

1. Show the **player** diagram; start at the black initial node.
2. Follow sign-in, including the lockout loop after 3 wrong passwords.
3. Follow one round: wrong guess loops back while tries are left; the first correct solve hits the **fork bar**.
4. Mention the admin diagram in one sentence (sign-in, sections by permission, sign-out).

Say (about 40 seconds): This activity diagram shows every path a player can take. They sign in by email, Google, or a new account; three wrong passwords in 15 minutes lock the account. In a round, a wrong guess loops back while tries remain. The first correct solve reaches this fork bar: four things happen together, minting KK, unlocking the next level, funding a palayok, and adding the heritage card. The administrator's diagram follows sign-in, the sections they are allowed to open, and sign-out.

Avoid: explaining every branch; forgetting what the fork and join bars mean.

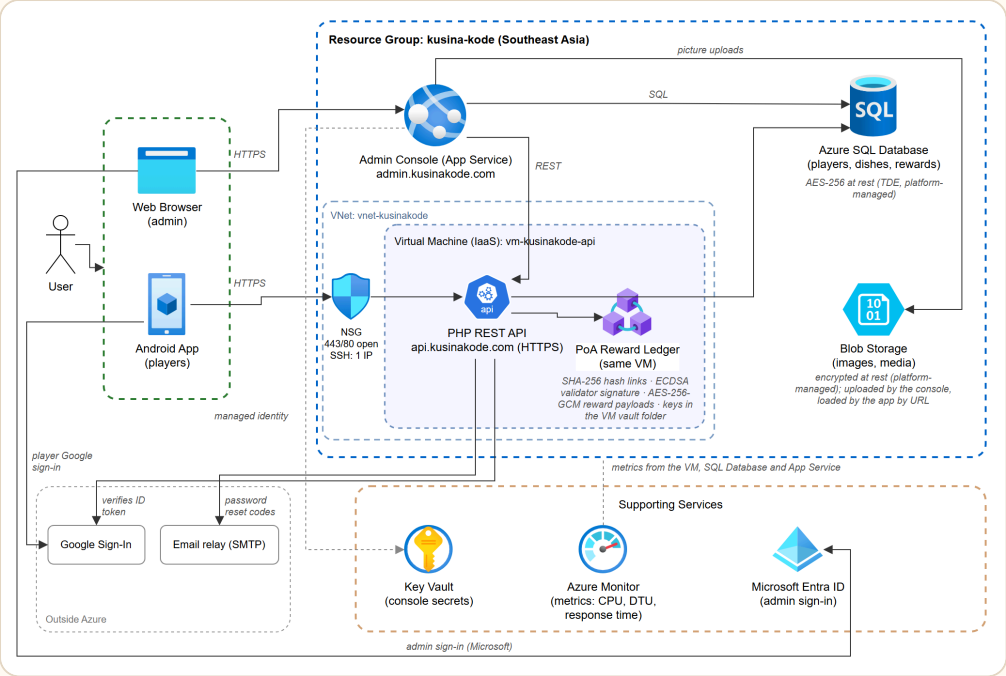
6.8 Other diagrams

`cloud · cybersecurity · conceptual framework`

CLOUD ARCHITECTURE

Shows **where each part runs**, using the provider's official icons and its containers: the resource group, the virtual network (VNet), the VM, the firewall rules (NSG). The service model matters: an **IaaS** VM for the API and ledger, **PaaS** for the console, database and storage.

SYMBOL	NAME	WHAT IT MEANS
	**Container**	Dashed groups nest: resource group, then VNet, then VM. Anything inside is managed or reached through its container.
	**Connection**	A network call, labelled with its protocol or purpose.

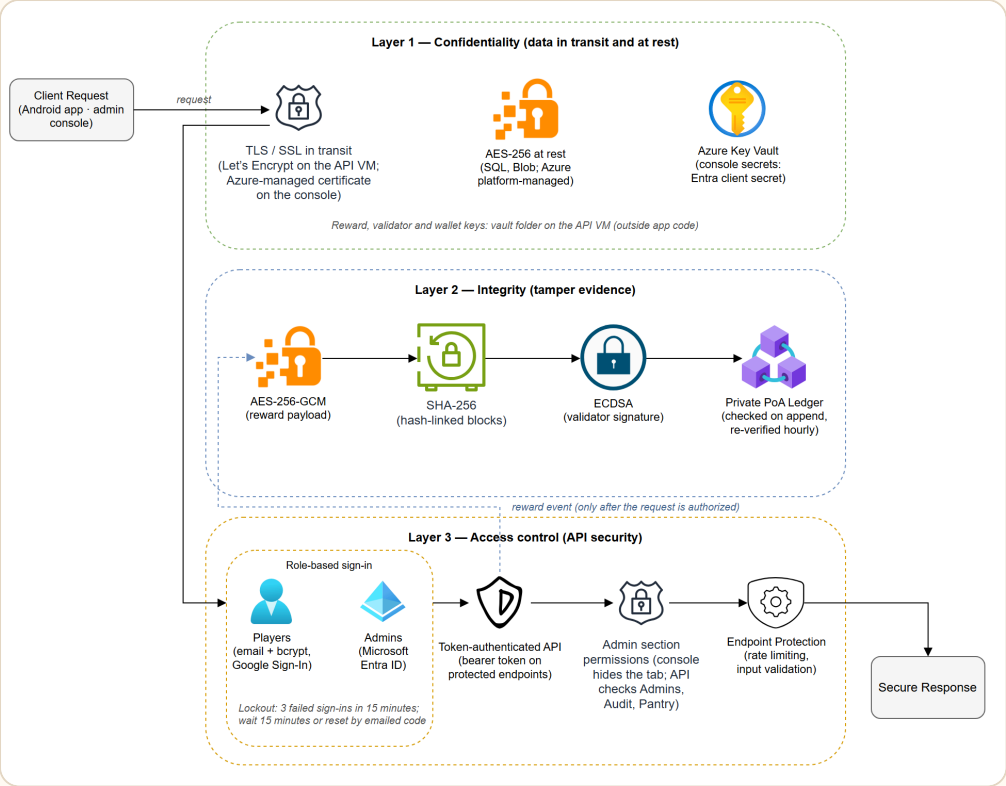


Every Azure resource in the `kusina-kode` resource group (Southeast Asia), plus the services outside Azure.

- Admins reach the console (App Service, `admin.kusinakode.com`) and sign in through Entra ID; the console reads its secret from Key Vault through its managed identity.
- Players reach the API through the NSG (443/80 open, SSH from one IP) on the VM, where the PoA ledger also runs.
- The console uploads pictures to Blob Storage; the app loads them by URL. Azure Monitor collects metrics from the VM, SQL Database and App Service.

CYBERSECURITY ARCHITECTURE

Shows the security controls grouped by the **CIA triad**: Confidentiality (data in transit and at rest), Integrity (tamper evidence), and Access control (who may do what).



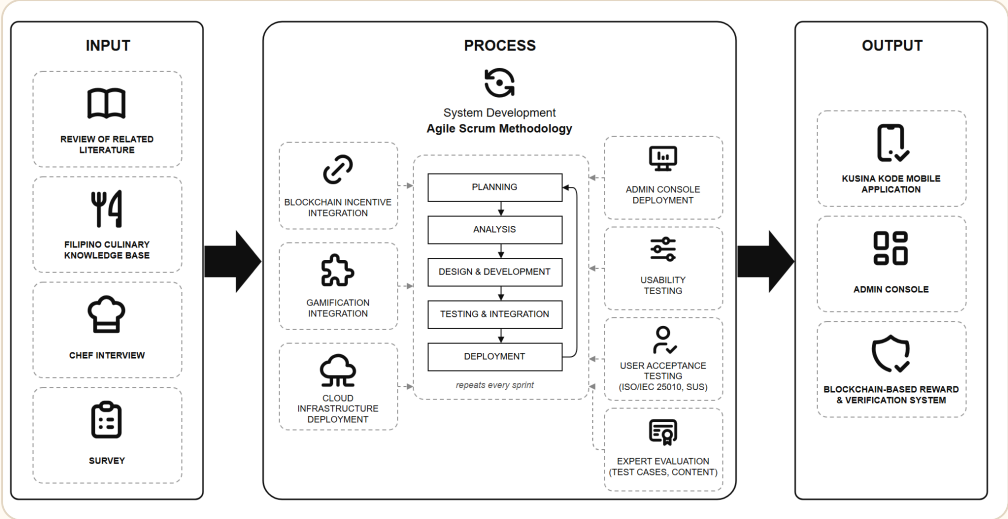
Three layers that every request passes through.

- **Layer 1:** TLS (Let's Encrypt on the API, an Azure-managed certificate on the console), AES-256 at rest, Key Vault for the console's secrets; the reward, validator and wallet keys sit in a vault folder on the VM.
- **Layer 2:** AES-256-GCM payloads, SHA-256 hash links and ECDSA signatures, checked when appended and re-verified hourly.
- **Layer 3:** role-based sign-in with the 3-tries lockout, a token on protected endpoints, section permissions (the console hides tabs; the API also checks Admins, Audit and Pantry), and rate limiting with input validation.

CONCEPTUAL FRAMEWORK

The research model, drawn as **Input** → **Process** → **Output** (IPO): what the study started from, what the team did, and what it produced.

SYMBOL	NAME	WHAT IT MEANS
	**IPO boxes**	Read left to right. The arrows mean "leads to", not data or network traffic.



Input, process (Agile Scrum, repeated every sprint) and output.

- **Input:** the review of related literature, the Filipino culinary knowledge base, the chef interview, and the survey.
- **Process:** Scrum (planning, analysis, design and development, testing and integration, deployment) repeated every sprint, with blockchain, gamification and cloud work on one side and the admin console, usability testing, UAT (ISO/IEC 25010 and SUS) and expert evaluation on the other.
- **Output:** the mobile app, the admin console, and the blockchain-based reward and verification system.

PANEL MIGHT ASK

Cloud vs system architecture? The system architecture shows the logical parts and tiers; the cloud architecture shows the actual Azure resources they run on.

Why is it called a "conceptual" framework? It shows how the study's ideas connect, not how the software is built.

HOW TO PRESENT IT TO THE PANEL

1. **Cloud**: point to the resource group, then the VNet, then the VM with the API and ledger; then the PaaS services.
2. **Cybersecurity**: name the three layers in order (confidentiality, integrity, access control) and one control in each.
3. **Conceptual framework**: read Input → Process → Output left to right, one line each.

Say (about 40 seconds): Cloud: everything runs in one Azure resource group in Southeast Asia. The API and the ledger run on a virtual machine inside a virtual network with firewall rules, while the console, the database, and storage are managed services. Cybersecurity: three layers, TLS and AES-256 for confidentiality, SHA-256 links and ECDSA signatures for integrity, and tokens, lockouts, and permissions for access control. Conceptual framework: our

inputs were the literature, the culinary knowledge base, the chef interview, and the survey; the process was Scrum; the outputs are the app, the console, and the reward ledger.

Avoid: presenting all three back to back; pick the one the slide or question is about.

Diagrams: DFD, ERD, process flows and data pipelines by Kyla (14 to 15 Oct 2026); use case, system architecture, activity diagrams, cloud and cybersecurity architecture and the conceptual framework by Mau (draw.io, 15 Oct 2026). Checked against the API, console and app code and the Azure SQL schema on 15 Oct 2026.

UNIT 7 · TEST YOURSELF

Concept checks and panel drills

Tap a card to reveal the answer. Answer out loud first. In a group: one person asks, one answers without looking, the others check.

7.1 Research design and statistics

Concepts the panel tests when you defend your method and results.

✓ What is a descriptive-evaluative research design?

It describes the system as built and evaluates it against set standards (ISO/IEC 25010, SUS, test cases) with numbers, without manipulating variables or comparing to a control group.

> Ours is also developmental: we built the system, then evaluated it.

✓ Purposive vs convenience sampling?

Purposive: chosen on purpose for a trait (the expert; culinary and HM students who know the cuisine). Convenience: whoever is available (Cohort B, other programs).

> Neither is random, so results describe these respondents and are indicative, not generalizable to all students.

✓ Why a four-point Likert scale?

With no neutral middle, respondents must lean agree or disagree; a midpoint can become a safe default (Kusmaryono et al., 2022).

> Interpretation: 3.26–4.00 Strongly Agree · 2.51–3.25 Agree · 1.76–2.50 Disagree · 1.00–1.75 Strongly Disagree.

✓ What is a weighted mean?

The average of ratings where each scale value is multiplied by how many chose it: Σ(value × frequency) ÷ total responses.

> Overall ISO/IEC 25010 = 3.70 across 61 respondents.

✓ How is SUS computed?

For the 10 items (1–5): odd items score (answer − 1); even items score (5 − answer). Add the ten, multiply by 2.5 → 0 to 100.

> 68 is the commonly used average; ours: 70.6 (all 61). It is not a percentage.

✓ Why Mann-Whitney U and not a t-test?

The data are ordinal ratings and the groups are small (20 and 40), so a rank-based, non-parametric test is appropriate (Field, 2018). A t-test assumes interval data and normal distributions.

✓ **What does p = .220 mean?**

If there were truly no difference, a difference at least this large would appear about 22% of the time. Since p > .05, we found no significant difference.

> It does not prove the groups are equal. "Absence of evidence is not evidence of absence."

✓ **What is an effect size (r)?**

How big a difference is, regardless of sample size: .10 small, .30 medium, .50 large (Cohen, 1988). Ours: .16 (ISO) and .05 (SUS), both small.

✓ **Spearman vs Pearson correlation?**

Pearson measures a straight-line relationship between interval values; Spearman correlates the ranks, so it suits ordinal data and outliers. Ours: ρ = .59, a strong positive relationship.

> ρ^2 = .35: about a third of the variation is shared. Correlation is not causation.

✓ **Why screen out careless responses?**

Answering the same option for all ten SUS items gives exactly 50.0 regardless of opinion (insufficient effort responding; Huang et al., 2012). We flagged runs of 7+ identical answers (Johnson, 2005), kept all data, and report the 81 before screening in Appendix U.

✓ **Acceptance vs effectiveness?**

Acceptance = users rate the system positively and can use it (what we measured). Effectiveness = it improves learning, which needs a pre-test and post-test design (not measured; recommended).

✓ **ISO/IEC 25010 has eight characteristics. Why only five?** prepare

Suggested answer: we evaluated the five that users can judge from using the app (functional suitability, performance efficiency, usability, reliability,

security). Compatibility was tested by the team on browsers and devices, and maintainability and portability concern the code rather than the user.

> **Not written in the manuscript.** Chapter 3 names the five but gives no reason; agree on this answer as a group or add a sentence to Chapter 3.

7.2 Software engineering and testing

Method and testing vocabulary.

✓ **Scrum vs Waterfall?**

Waterfall runs phases once in sequence (requirements → design → build → test). Scrum repeats short sprints that each deliver a working, tested increment, so feedback changes the next sprint.

✓ **Scrum roles and events?**

Roles: Product Owner (Chef Gicana), Scrum Master (Jhan Maurice), Development Team. Events: sprint planning, the sprint, sprint review, sprint retrospective. Artifacts: product backlog, sprint backlog, increment.

✓ **Unit vs integration vs system vs acceptance testing?**

Unit: one function in isolation. Integration: parts working together (app ↔ API). System: the whole deployed system (stress, security, cloud, compatibility). Acceptance: the user or expert confirms it meets needs (our 23 expert test cases).

✓ **Load vs stress testing?**

Load testing checks behaviour at expected load; stress testing pushes beyond it to find the breaking point. Ours ramped 5 → 40 players; no request failed and the database was the limit.

✓ **SAST vs DAST?**

Static (SAST) reads the source code without running it (Semgrep). Dynamic (DAST) attacks the running application from outside (OWASP ZAP).

✓ **What is regression testing, and CI?**

Regression testing re-runs tests after a change to catch new breakage. Continuous integration runs the tests automatically on every change; ours run on GitHub Actions for every pull request.

✓ What is MVVM?

Model-View-ViewModel: the View (screen) shows state, the ViewModel holds state and handles actions, the Model holds data and rules. Screens never call the network directly.

✓ What is a REST API?

An interface over HTTP where URLs name resources and methods state the action (GET read, POST create, PUT/PATCH update, DELETE remove), usually exchanging JSON. Ours: the PHP REST API at api.kusinakode.com.

✓ HTTP 200, 401, 403, 429?

200 OK. 401 Unauthorized: not signed in or bad token. 403 Forbidden: signed in but not allowed. 429 Too Many Requests: our lockout after too many failed attempts.

7.3 Security and blockchain

The most-tested area, because blockchain is the main contribution.

Hashing vs encryption?

Encryption is reversible with a key (AES-256 hides the reward data). Hashing is one-way: SHA-256 gives a fingerprint that cannot be turned back into the data, used to detect changes.

Symmetric vs asymmetric cryptography?

Symmetric uses one shared key to encrypt and decrypt (AES). Asymmetric uses a key pair: private to sign or decrypt, public to verify or encrypt (ECDSA signatures).

What does a digital signature prove?

Authenticity (it came from the holder of the private key, our validator) and integrity (it was not changed). It also gives non-repudiation.

Why are passwords hashed with bcrypt?

bcrypt is deliberately slow and salted, so stolen hashes are expensive to guess (about 66 ms per hash in our test). A fast hash like SHA-256 would let attackers try billions per second.

Does the app use the blockchain to sign in?

Not to check who you are. Sign-in is a bcrypt-checked password or a verified Google token, then a session token, all in the database. After it succeeds, the API records a 0 KK `account_login` (or `account_signup`) event on the ledger through the four-phase pipeline, with its own receipt.

> Say: "The blockchain doesn't authenticate the user; it records the sign-in, so account activity is as tamper-evident as rewards." In the app it appears in the reward history as "Account Login", marked Secured.

Authentication vs authorization?

Authentication: who are you (password, Google, Entra). Authorization: what you may do (your token's identity, admin section permissions).

✓ **What is the CIA triad?**

Confidentiality (only the right people see data), Integrity (data is not changed undetected), Availability (the system stays usable). Our cybersecurity architecture is organized by it.

✓ **Proof-of-Work vs Proof-of-Stake vs Proof-of-Authority?**

PoW: miners spend computing power (Bitcoin). PoS: validators lock up coins (Ethereum today). PoA: approved, known validators sign blocks; fast and free, but trust rests on the validators. Ours: PoA with one validator.

✓ **Tamper-evident vs tamper-proof vs decentralized?**

Tamper-evident: changes are detected (ours: hash links and signatures, verified hourly). Tamper-proof: changes are impossible. Decentralized: no single party controls the ledger. Ours is tamper-evident, not decentralized.

✓ **What is a smart contract, and do you have one?**

Code that automatically executes rules on a blockchain. Our KKCoin and KKBadge "contract rules" run in the API in Phase 4; they are not deployed on a public chain.

✓ **What is a custodial wallet?**

The platform holds the keys for the user. Players need no seed phrase, wallet app, or gas fees; the trade-off is that players trust the platform.

✓ **What is SQL injection, and how are you protected?**

Input crafted to change a database command (' OR '1'='1). We use prepared statements with bound parameters, so input is never treated as code; tests refused the payloads and the users table stayed intact.

✓ **What is zero trust?**

"Never trust, always verify": every request is checked, regardless of where it comes from. Every protected endpoint verifies the bearer token (Chandramouli & Butcher, 2025).

7.4 Data, algorithms, and architecture

Short definitions you should say in one breath.

✓ 1NF, 2NF, 3NF?

1NF: one value per cell, no repeating groups. 2NF: 1NF and every non-key column depends on the whole key. 3NF: 2NF and no column depends on another non-key column. We moved comma-separated lists into child tables (October 12–13).

✓ Primary key vs foreign key?

A primary key uniquely identifies a row; a foreign key points to another table's primary key to link them. A composite key uses several columns (reward_claims: user, kind, claim key).

✓ What is O(n)? O(1)? O(n log n)?

How running time grows with input size n. Tile scoring is O(n) (two passes over the word); a hash map lookup is O(1) on average; the leaderboard sort is O(n log n).

✓ Why two passes in tile scoring?

Greens must be claimed first; otherwise a yellow could use up a letter that a later position needs for a green. This fixed the repeated-letter defect (D-01).

✓ What is a hash-linked chain?

A list where each block stores the hash of the previous block; changing any block breaks every later link. It is the core data structure of a blockchain.

✓ Clean Architecture in one line?

Inner layers (business rules) never depend on outer layers (database, UI), so rules can be tested alone and outer parts swapped. Used in both the app and the console.

7.5 Skill drills

Work it out first, then open the card to check. Panels sometimes ask you to compute or trace on the spot.

✓ **Drill 1: A respondent answers the 10 SUS items 4, 2, 4, 2, 4, 2, 4, 2, 4, 2. What is the SUS score?** compute

Odd items: (4 − 1) × 5 = 15. Even items: (5 − 2) × 5 = 15. Total 30 × 2.5 = **75.0** (Good, above 68).

✓ **Drill 2: Interpret weighted means of 3.43 and 3.20.** interpret

3.43 is **Strongly Agree** (3.26–4.00), like our lowest item R4. 3.20 would be **Agree** (2.51–3.25).

✓ **Drill 3: Answer ADOBO, guess OBODA. Colour each tile.** trace

Pass 1: position 3 (O = O) is green. Remaining answer letters: A, D, B, O. Pass 2: O yellow (uses the last O), B yellow, D yellow, A yellow. Result: **yellow, yellow, green, yellow, yellow**.

✓ **Drill 4: A player solves a new dish on the 3rd try in 45 seconds. How much XP?** compute

100 + 20 × (6 − 3) = 160; not a first try (+0); under 60 s (+40). Total **200 XP**.

✓ **Drill 5: Read this ERD line: users ||——o< attempts.** read

One user has **zero or many** attempts; each attempt belongs to **exactly one** user.

✓ **Drill 6: Which diagram answers "who does each step when an admin adds a level"?** choose

The **process flow** (PF2): it follows one scenario across swimlanes. The DFD shows data movement but not order.

✓ **Drill 7: Someone edits a block in blocks.jsonl. What happens?** reason

Its hash no longer matches the hash stored in the next block, and its ECDSA signature fails, so the **hourly verification** reports a broken link. That is tamper-

evidence.

✓ **Drill 8: A request returns HTTP 429 after the 4th wrong password. Correct?**

reason

Yes. The account allows 3 failed attempts in 15 minutes; the 4th is refused with 429 account_locked, and the lock lasts 15 minutes.

7.6 Panel questions with answers 45 questions

Say the short answer first (about 20 seconds); the grey part is for follow-ups. Same list as the presentation guide.

Problem, rationale, and contribution

✓ **What problem does Kusina Kode solve?**

Filipino culinary heritage has no structured, engaging digital learning tool: content is scattered, popular apps are international, and gamified apps keep rewards as editable records. Kusina Kode combines expert-validated Filipino dish content, a word puzzle, gamification, and verifiable rewards in one platform.

> Evidence: pre-development survey of 64 (mobile apps least used, 7.8%; 89.1% valued expert-validated recipe information), the expert interview (no Filipino-focused app; Mindanao underrepresented), and the literature on editable reward records (Motepalli & Jacobsen, 2021).

✓ **What is the main contribution of the study?**

The blockchain-based incentive system: every reward goes through encryption, hashing, signing, and contract rules on a private Proof-of-Authority ledger and produces a TxHash receipt, so rewards in an educational game can be verified.

> Chapter 5 names objective C as the main contribution. It is integrated with gamified heritage learning, which the reviewed systems (Table 1) do not combine.

✓ **Why Filipino culinary content and why gamification?**

Culinary heritage carries regional identity and is at risk of fading as recipes receive less attention; gamification is well documented to raise motivation and engagement in education.

> Gelera et al. (2023) on fading regional dishes; Oliveira et al. (2023), Jaramillo-Mediavilla et al. (2024), and Lampropoulos & Sidiropoulos (2024) on gamified learning. The puzzle and heritage content give intrinsic motivation; points, badges, and KK give extrinsic motivation (John et al., 2023).

Objectives, scope, and limitations

✓ **Were all three objectives met?**

Yes, in terms of building and evaluating the features: A, the puzzle and validated content (FS1 3.79, cultural content 4.00); B, accurate gamification (FS5 3.84,

38 unit tests); C, verifiable rewards (391 of 391 checks, FS8 3.85).

> Each objective maps to modules, unit tests, and questionnaire items. "Met" does not mean learning gains, which were not measured.

Why did you not measure whether students learned more?

It is outside our scope, stated in the delimitations. Our evaluation measures acceptance, software quality, and usability. Measuring learning needs a pre-test and post-test over several weeks, which is our final recommendation.

> Chapter 1 delimitation: the study does not measure how effective the platform is at promoting culinary education and cultural awareness. Chapter 5 recommends a longitudinal study.

What are the main limitations?

One expert, small cohorts, a usability score near the threshold, a single validator key, reward keys still on the VM disk, and some planned tests not yet run (simultaneous spending, older and newer Android versions, live security tests).

> All are stated in Chapter 4 (end of Sprints 11 and 12) and lead to the recommendations in Chapter 5.

Research design, sampling, and screening

What is your research design?

Quantitative, descriptive-evaluative, with a developmental approach: we built the system in twelve Scrum sprints and evaluated it against ISO/IEC 25010 and the SUS.

> Chapter 3, Research Design. Instruments: 23 test cases (expert), ISO/IEC 25010 questionnaire (4-point scale), SUS. Analysis: weighted mean, SUS formula, Mann-Whitney U, Spearman's ρ.

Why purposive and convenience sampling? Is the sample representative?

The expert and Cohort A were chosen purposively for their culinary knowledge; Cohort B by convenience to represent general students. The sample is not random, so results describe these respondents and are indicative, not generalizable.

> Cohort A: 13 Culinary Arts and 7 Hospitality Management students. Cohort B: 40 students from other MMCL programs. Chapter 4 calls the usability results indicative and not precise.

Why were 20 Cohort B responses removed? Is that cherry-picking?

They were not deleted. In the first batch many respondents gave the same answer to all ten SUS statements, which gives exactly 50.0 regardless of opinion. We screened for runs of seven or more identical answers (Johnson, 2005), collected more responses under closer supervision until 40 passed, and report all 81 in Appendix U.

> Before screening, all 81 averaged SUS 65.6; the 61 who passed averaged 70.6. The sensitivity analyses in Appendix U point the same way: usability is close to the threshold. We also recommend setting the screening rule before data collection next time.

Why a four-point scale without a neutral option?

To make respondents take a stance; a neutral midpoint can become a safe default (Kusmaryono et al., 2022).

> Interpretation: 3.26–4.00 Strongly Agree, 2.51–3.25 Agree, 1.76–2.50 Disagree, 1.00–1.75 Strongly Disagree (Table 3).

Blockchain

Why use blockchain at all? A database could store rewards.

A normal database row can be changed without trace. Our ledger signs every reward and links each block to the previous one by its hash, so any change is detected when the chain is verified. That gives players and admins verifiable proof of what was earned.

> Respondents rated S3 (verifying rewards increases trust) 3.77 and FS8 (coins and badges match what was earned) 3.85, the highest item.

Why a private, permissioned ledger instead of Ethereum or Polygon?

Players should not need a crypto wallet, seed phrase, or gas fees, and KK Coins are not meant to be traded. A private Proof-of-Authority ledger gives tamper-evidence without those costs.

> Chapter 2 compares public platforms (Polygon, Ethereum, Solana, Hyperledger Fabric). Custodial wallets keep the experience simple; U6 (rewards usable without knowing blockchain) 3.49 shows players used rewards without needing to understand the ledger.

If your team holds the only validator key, can you not rewrite the chain?

Yes, and we state it: the ledger is tamper-evident, not decentralized. Any silent edit is detected when the chain is verified from its genesis block, but nothing stops the operators from rebuilding it. We recommend independent validators or anchoring block hashes on a public network.

> Delimitations (Chapter 1) and Chapter 5. The chain is re-verified every hour; the cloud test verified 4,315 blocks in 6.5 seconds with no broken link or bad signature.

✓ **What is Proof-of-Authority?**

A consensus method where only approved validators may add blocks; a block is valid only if it carries an approved validator's signature.

> Our harness tests that a block signed by a rogue validator and a forged signature are both rejected (391 checks).

✓ **Explain encryption, hashing, and digital signatures in your pipeline.**

AES-256-GCM encrypts the reward data so it stays private; SHA-256 creates a fingerprint that changes if any bit changes; ECDSA signs the record with the validator's private key, proving it came from our system.

> Measured cost: AES-256-GCM 0.021 ms, SHA-256 0.002 ms, ECDSA sign 0.40 ms and verify 0.37 ms (MacBook Air M2), so cryptography is not the bottleneck.

✓ **What are the KKCoin and KKBadge contracts? Are they smart contracts?**

They are the contract rules our API runs in phase 4 to decide how many KK Coins or which badge a reward produces; they are not deployed on a public blockchain.

> Phase 4 applies the rules and issues the TxHash receipt; KK minting and spending are covered by the test harness.

✓ **What is a TxHash receipt and how does a player use it?**

The unique hash of a recorded reward. Players open it in the wallet as a ledger ticket that shows the reference, date, amount, and "Verified on the ledger"; admins see it in the Audit log.

> UAT case D3 (open a transaction's ledger ticket) passed. The Audit log also shows chain totals (E5).

Where are the keys stored? Is that secure?

The console's secrets are in Azure Key Vault. The reward encryption, validator, and reward keys are files on the VM, readable only by the server account, with an encrypted copy held off the machine since October 17. Moving them into Key Vault is our open cloud finding and a recommendation.

> Cloud test: 42 of 43 checks passed; this is the one open finding.

Architecture and deployment

Describe the system architecture.

Android app (Kotlin, Jetpack Compose, MVVM with Clean Architecture) and admin console (ASP.NET Web Forms on Azure App Service) talk over HTTPS to a PHP REST API on an Azure VM with the ledger; data is in Azure SQL Database, pictures in Blob Storage, secrets in Key Vault.

> Admins sign in with Microsoft Entra ID; one emergency password account is the backup. The API takes the player's identity from the signed token.

Why Azure, and why a VM for the API?

Azure provides managed SQL, storage, App Service, and Key Vault in one place; the VM gives the control needed to run the ledger and its file-based chain store.

> Hybrid IaaS (VM) plus PaaS (App Service, SQL, Blob), Southeast Asia region. Chapter 2 and Chapter 3 justify the choice.

Tell us about the database.

Azure SQL Database, normalized during Sprint 9 from 21 to 36 tables with 43 enforced links; lists stored in cells were moved into their own tables.

> The change was staged on a copy and checked; API replies were identical before and after. Appendix AB is the data dictionary.

What can the admin console do?

Manage the Levels, Ingredients, Equipment, and Reels catalogs; view players, KK Coins, Pantry Kodex, and the Audit log; manage admins with per-section permissions.

> Ten tabs in four groups; sessions end after 15 minutes of inactivity; 12 of 12 console integration cases passed; all 55 browser checks passed.

Testing: security, reliability, performance, compatibility

✓ How did you test security?

Code review and fixes (identity from token, no raw database errors, exclusive locks, HTTPS), direct tests of login and reset-code lockouts and SQL injection, and scans with Semgrep and OWASP ZAP.

> Login locks on the 4th wrong password, reset code on the 6th (HTTP 429). ZAP: 0 High, 12 Medium, 14 Low, 11 Informational. Following NIST SP 800-115 (Scarfone et al., 2008).

✓ Why were security tests run on a local copy and not the live server?

Lockout and injection tests would lock or affect real accounts. We ran them on a copy and repeated the lockout on the live API with an email that has no account.

> Chapter 4 states this as a limit and recommends repeating the tests on a staging copy.

✓ What did OWASP ZAP's 12 Medium alerts mean?

Configuration issues of the local test server, such as error display, directory browsing, and missing headers and anti-forgery tokens; no High alert and no SQL injection alert.

> They fall under security misconfiguration in the OWASP Top 10 (2021). The live console already removed its server-identifying headers (Issue 21).

✓ How does the system perform under load?

All 2,316 API requests succeeded with up to 40 simultaneous players. Average response was under 1 s up to 20 players and 1.6 s at 40, within the 10-second limit; the database tier is the bottleneck.

> Nielsen (1993) limits: 0.1 s instant, 1 s flow, 10 s attention. Database at 91% capacity, server processor ≤ 12%. JMeter in QA Round 2: 400 requests, average 1.33 s.

✓ Why did respondents mention lag?

On a mid-range phone the animated screens missed many frames (57% overall, 94% on the Game Map) against the 16 ms target, though the app never crashed. On a flagship only 4.2% were missed.

> Issue 20 changed the map animation in build 1.27; the comparison was inconclusive, so further optimization is a recommendation. Three respondents

> mentioned lag; PE1 3.54 and R1 3.57.

Why only Android 11 to 13 in compatibility testing?

Those were the six real devices available on BrowserStack App Live that we tested (Pixel 6 and 7, Galaxy S23, vivo Y21, Oppo A78, Galaxy Z Fold 5). Android 8–10 and 14+ are not yet checked, which we state as a limit.

> All 30 device checks passed; Android fragmentation is a known source of compatibility issues (Wei et al., 2016).

What is QA Round 2 and who ran it?

A second round on October 19, 2026 by our QA tester, who did not write the code under test, on app 1.31 and the latest web commit: 13 checks, 11 passed and 2 were scan reports.

> Table 7 and Appendix AD. The one UI test that failed was a leftover template test checking an old package name; it was corrected and passed on October 20.

Did you test two people spending KK at the same moment?

Not with real simultaneous requests, because each purchase writes a permanent receipt to the live ledger. The exclusive lock was tested on the server; a simultaneous test is planned for a staging copy.

> Issue 4 and the testing limits in Chapter 4.

ISO/IEC 25010 and SUS results

What do the ISO/IEC 25010 results mean?

All 61 respondents' mean ratings were Strongly Agree on all five characteristics: overall 3.70, highest functional suitability 3.76, lowest reliability 3.60; 97.5% of 1,830 ratings were Agree or Strongly Agree.

> Table 10. Cohort A rated every characteristic lower than Cohort B; the expert rated all 4.00.

Your SUS is 70.6, close to 68. Is the usability good enough?

It is Acceptable but close to the threshold, and the medians are 67.5. We read it as acceptable with room to improve, mainly in the first session, which matches the feedback asking for hints and a guide.

> Table 11: expert 87.5, Cohort A 69.1, Cohort B 70.9, all 61: 70.6. Spearman suggests the lowest quality items (R4, U6, PE1) are likely levers, although an association cannot prove it.

✓ **Why is the ISO rating Strongly Agree while SUS is only Acceptable?**

They measure different things on different scales: ISO/IEC 25010 rates software quality characteristics on a four-point agreement scale; SUS measures perceived ease of use on a 0–100 scale. Both are favorable, and they correlate (ρ = .59).

> Different anchors: 3.26 for Strongly Agree versus 68 for acceptable usability.

✓ **What is the difference between UAT, usability testing, and software quality evaluation in your study?**

UAT is the expert carrying out 23 test cases (23 of 23 passed). Usability is the SUS answered by all 61. Software quality is the ISO/IEC 25010 questionnaire answered by all 61. Technical system tests are separate and run by the team.

> Chapter 3, Data Gathering (System Evaluation) and Data Analysis.

Cohort comparison and statistics

✓ **Why Mann-Whitney U and not a t-test?**

The ratings are ordinal and the groups are small (20 and 40), so a rank-based test is appropriate (Field, 2018).

> Ties corrected; effect size r read against Cohen's benchmarks.

✓ **What did the cohort comparison show?**

No significant difference: ISO/IEC 25010 U = 321.5, p = .220, r = .16; SUS U = 375.5, p = .706, r = .05. Culinary and non-culinary students responded alike, so the 61 can be read as one sample.

> With 20 and 40 respondents the test could miss a small difference, so this shows similar acceptance, not proof of equivalence.

✓ **Does p = .220 mean the cohorts are the same?**

No. It means the data do not show a significant difference at the .05 level. Absence of evidence of a difference is not evidence of equivalence.

> An equivalence test would need larger samples and a predefined margin.

✓ **What does the Spearman correlation tell us?**

ρ = .59, p < .001: respondents who rated quality higher also found the platform easier to use, so the two instruments agree. About a third of the variation is shared (ρ^2 = .35).

> Students only: ρ = .58, so it does not depend on the expert. It is an association, not a cause, and both questionnaires were answered in one session.

✓ **Why did Cohort A, the culinary students, rate lower?**

Their ratings were slightly lower on every characteristic, especially reliability (3.46), but the difference was not significant (p = .220). As domain-familiar users they may have been more critical; we report this without overinterpreting it.

> Chapter 4 notes Cohort A's ratings are the lowest of the student groups and, with 20 respondents, imprecise.

Acceptance versus educational effectiveness

✓ **Can you say Kusina Kode improves Filipino culinary knowledge?**

No. We can say it was accepted, rated high in quality, and found usable. Learning gains were not measured; that requires a pre-test and post-test design.

> Chapter 1 delimitation and Chapter 5 recommendation (longitudinal study).

✓ **Then how do you support objective A, which is about learning?**

Objective A is to provide a module that supports learning. We built it with expert-validated content (rated 4.00 by the expert), and respondents rated its function highly (FS1 3.79). Whether it produces learning is the next study.

> 89.1% of survey respondents valued expert-validated recipe information; the content answers that need.

Limitations and recommendations

✓ **What would you do first if you continued the project?**

Improve onboarding (region first, free early hint, skippable animations), then measure learning gains, then strengthen ledger trust with independent validators

or public anchoring.

> All eight recommendations are in Chapter 5 and trace to a finding.

✓ **Is the system ready for public release?**

Not yet. Before release we recommend faster animated screens, a higher database tier, moving the reward keys into Key Vault, running the remaining tests on a staging copy, and publishing on Google Play.

> Three respondents, including the expert, asked for app store availability.

✓ **The evaluation sessions were not all supervised the same way. Does that affect the results?**

Yes, the first Cohort B batch was supervised less closely, which is why its responses were screened. We document it in Appendix U and recommend one supervised procedure for all sessions.

> Results before and after screening point the same way: usability near the threshold.

✓ **Some references in your list: can you show us the source?**

Have the PDF or DOI of each reference ready. All in-text citations match the reference list, and 131 DOIs were checked against Crossref.

> Eight references are still being confirmed by the team (Hema, Cabuenas, Gala, Awaji, Waja, Rahmat, Peng, Chaurasia); confirm or replace them before the defense.